

Cybersecure and Cyber-Resilient European Cloud–Edge–IoT Computing Continuum: A Strategic Roadmap

ANONYMOUS¹,

¹Affiliation 1 (e-mail: author1@domain)

ABSTRACT The distribution of computation, storage, networking, and Artificial Intelligence (AI) capabilities across cloud, edge, and Internet of Things (IoT) ecosystems is transforming cybersecurity, resilience, and digital sovereignty into a strategic coordination challenge for Europe. Cloud–edge decentralisation changes the threat model because infrastructures become too large, heterogeneous, geographically dispersed, resource-constrained, and strategically exposed to be protected through perimeter-centric security alone. It expands attack entry points, fragments visibility and trust zones, exposes physically deployed edge nodes, increases privacy risks close to the physical world, and creates new attack surfaces around AI pipelines, real-time services, supply chains, and long-term cryptographic exposure. At the same time, Network and Information Security Directive 2 (NIS2), the Cyber Resilience Act (CRA), the AI Act, and Digital Operational Resilience Act (DORA) require security and resilience obligations to be translated into deployable architectures, continuous assurance mechanisms, and ecosystem-level coordination. This paper develops a cybersecurity and cyber-resilience roadmap for the European Cloud–Edge–IoT continuum. Its contribution is a layered, capability-anchored, and regulation-aligned framework that connects architectural decomposition, priority clustering, 2026–2040 transition matrices, and implementation recommendations. The roadmap supports a transition from reactive and fragmented protection towards autonomous, federated, Security-by-Design, and resilient infrastructures under a sovereignty-oriented lens.

INDEX TERMS Certification, Cloud–Edge–IoT continuum, confidential computing, Critical Enabler, cyber-resilience, digital sovereignty, European Union, federated infrastructure, post-quantum cryptography, security roadmap, supply-chain attestation, Zero Trust architecture.

I. INTRODUCTION

The shift from centralised cloud to a distributed Cloud–Edge–IoT continuum brings computation, storage, networking, and AI inference closer to devices, users, and physical processes [1]–[3]. The architectural gains, including lower latency, higher operational autonomy, and proximity of data processing, redefines the cybersecurity threat model along five coupled dimensions. The continuum becomes more *numerous (too many)*, with attack entry points multiplying across devices, Application Programming Interfaces (APIs), data-transfer interfaces, workloads, and orchestration planes; more *heterogeneous (too diverse)*, with diverse hardware, firmware, operating environments, providers, and deployment models that resist uniform hardening; more *dispersed (too dispersed)*, with geographically distributed Edge–IoT nodes operating under weaker physical protection, frag-

mented monitoring, and inconsistent controls; more *constrained (too limited)*, with edge and IoT devices limited in compute, memory, energy, and security capabilities; and exposed to more *capable* adversaries who combine AI-enabled offensive techniques, supply-chain compromise, lateral movement across trust zones, spoofing and impersonation, real-time service exploitation, physical tampering, and “Harvest Now, Decrypt Later” attacks against long-lived encrypted data [4]–[8].

Perimeter-oriented security models designed for consolidated data-centre environments cannot satisfy this evolving threat landscape; continuum security must be enforced through Security-by-Design mechanisms applied across the lifecycle, including shift-left vulnerability handling, continuous DevSecOps, Zero Trust reference architectures, secure-by-default edge devices and communications, automated cer-

tification, and continuous assurance [4], [9]–[11]. Each relocation of workload across providers and jurisdictions is also a transfer of control, which makes continuum security inseparable from digital sovereignty, understood here as the ability to govern, audit, and operate critical infrastructure under credible European influence. This coupling between continuum security and digital sovereignty is reinforced by three concurrent pressures: non-European hyperscaler dominance in the EU cloud market, which creates dependency, control, and sovereignty concerns [12]; migration to post-quantum cryptography under a binding European framework, which requires coordinated technical transition [13]; and the weaponisation of generative AI, which expands the threat landscape for both human operators and AI-enabled defences.

Europe faces this transition under a broader and continuously evolving EU regulatory landscape, including core cybersecurity and resilience instruments such as NIS2 [14], the CRA [15], the AI Act [16], and DORA [17]. Together, these instruments raise the baseline of mandatory security, resilience, and accountability obligations across Information and Communication Technology (ICT) services, high-risk AI systems, and financial-sector third-party providers. The EU cybersecurity certification framework [18], [19] provides a mechanism for demonstrating that these regulatory obligations are implemented in practice. The challenge is therefore not only legal alignment, but the ability to translate regulatory obligations and strategic ambition into deployable security architectures, lifecycle controls, and continuous assurance mechanisms. This translation is difficult because continuum infrastructures must remain trustworthy under cyberattacks, geopolitical disruption, supply-chain uncertainty, and system-level failures affecting communication and orchestration infrastructure. At the same time, Europe has strong normative leadership in trust, privacy, governance, and certification [20], [21]; the strategic question is whether this leadership can be converted into operational capability and industrial advantage. Operationalisation of this combined regime remains uneven: national transposition lags the legal timetable in several large Member States [22], European Cybersecurity Competence Centre (ECCC) for Cloud Services remains unadopted [23], and conformity-assessment infrastructure for AI-specific security obligations is not yet in place [24].

This mismatch between ambition and deployable capacity is referred to in this paper as the *ambition–implementation gap*. Closing this gap requires a transition from reactive and siloed security towards autonomous, federated, Security-by-Design, and resilient infrastructures: systems that sustain trustworthy operation under adverse conditions, security mechanisms that span providers and jurisdictions, and assurance embedded throughout the system lifecycle [4], [10], [11]. A *roadmap* is therefore understood here as a coordination tool that links current capability gaps to future target states through phased actions, dependencies, transition conditions, and implementation recommendations. It aligns research, innovation, policy, standardisation, deployment, and ecosystem investment over time [3]. The *Cloud–Edge–IoT*

continuum refers to the interdependent execution environment in which computation, storage, networking, sensing, and AI inference are distributed across cloud platforms, edge infrastructures, and resource-constrained devices [1]–[3], [25]. The term *ecosystem* denotes the wider set of providers, standards bodies, regulators, certification schemes, open-source communities, research infrastructures, Small and Medium-sized Enterprises (SMEs), industrial actors, and public authorities whose decisions shape deployment capacity [3], [18], [19].

The paper makes five contributions. First, it proposes a three-stage methodology for constructing cybersecurity roadmaps under ecosystem uncertainty, combining architectural decomposition, priority clustering with seven-dimension analysis, and phased transition-matrix projection, while using Sovereignty Level as an interpretive strategic lens (Section III). Second, it decomposes the Cloud–Edge–IoT continuum into six Security Layers and four Transversal Security Cross-Layers, each populated with constituent capabilities, as the Stage 1 output (Section IV). Third, it consolidates these capabilities into three priority clusters: Sovereign Trusted Infrastructure, Cognitive Security and Autonomous Cyber Defence, and Federated Operational Sovereignty, analysed through the seven-dimension template as the Stage 2 output (Section V). Fourth, it develops three-phase transition matrices for the 2026–2040 horizon, using Operational Deployment State (ODS), Strategic Sovereignty Level (SovL), assessment perspectives, and Critical Enablers to express phase progression and transition conditions, as the Stage 3 output (Section VI). Fifth, it derives seven implementation-oriented recommendations for enforcing Security-by-Design across cloud–edge deployments, covering lifecycle integration, DevSecOps and continuous monitoring, Zero Trust (ZT) reference architectures, hardware-rooted trust, secure communication, automated compliance, and policy-driven incentives (Section VII).

Section II provides the strategic and regulatory context. Section III presents the three-stage methodology. Section IV defines the layered system model and its constituent capabilities. Section V presents the three priority clusters and their seven-dimension synthesis. Section VI presents the phase logic and cluster transition matrices. Section VII states the recommendations. Section VIII presents the discussion, limitations, and future work. Section IX concludes.

II. BACKGROUND AND DRIVING FACTORS

The first vector shaping the continuum transition is architectural: the continuum is characterised by decentralisation and physical exposure. Decentralisation complicates visibility, orchestration, patching, identity, and incident response across multiple administrative domains and increases the probability of inconsistent security postures across deployments [7], [8]. Physical exposure removes the environmental and access controls that hyperscale data centres rely on: edge nodes in factories, substations, transport hubs, and telecom sites are exposed to tampering, fault injection, side-channel attacks,

and supply-chain compromise [6]. Hardware roots of trust, secure boot, remote attestation, and tamper-aware design are therefore baseline requirements rather than optional enhancements [26], [27].

The European regulatory landscape constitutes a second major vector shaping the continuum transition. NIS2 [14], the CRA [15], the AI Act [16], DORA [17], the Data Act [28], and General Data Protection Regulation (GDPR) [29] together impose obligations that must be translated into architectures, assurance mechanisms, and lifecycle controls operating across cloud, edge, and IoT. This simultaneity creates disproportionate implementation pressures for SMEs and smaller Member States.

Sovereignty is the third vector. Dependence on non-EU providers for secure silicon, cloud platforms, and enterprise security tooling creates geopolitical and operational risk. Extra-territorial data access under foreign jurisdiction has been confirmed as a practical constraint for EU users of hyperscaler services [30].

Europe's position in this landscape is asymmetric. A world-leading regulatory foundation and a rigorous certification framework [18], [19] coexist with structural industrial gaps. EU-headquartered vendors (Infineon, NXP, STMicroelectronics) design the dominant secure-element products and achieved European Cybersecurity Certification Scheme on Common Criteria (Eucc) "High" certification for multiple product families in 2025 [31], but fabrication depends on non-EU foundries and designs remain proprietary, preventing sovereign auditability at the silicon level. Intel SGX/TDX, AMD SEV-SNP, and Arm TrustZone/CCA constitute the dominant operational hardware-backed Trusted Execution Environment (TEE) families across cloud, server, and embedded deployments; EU-origin RISC-V alternatives remain largely at research or prototype stage [32], and no EU-origin RISC-V processor has received Eucc or Common Criteria certification as of April 2026. The enterprise SIEM market is dominated by US platforms, with no EU-headquartered vendor in the Gartner Leaders quadrant as of late 2025 [33]. Hyperscalers continue to dominate the EU cloud market, while EU-headquartered providers retain a comparatively limited share, reinforcing concerns about dependency, switching costs, and the practical feasibility of sovereign cloud-edge federation [12]. For post-quantum migration the NIS Cooperation Group roadmap [13] now provides a binding framework, but production-scale post-quantum cryptographic (PQC) hardware tailored for edge and IoT is not yet available in Europe. This asymmetry between regulatory and certification leadership on the one hand, and structural industrial gaps on the other, is the empirical instantiation of the ambition–implementation gap that Section I introduces and that the methodology of Section III is designed to address.

Strategic roadmapping for digital infrastructure is now an established instrument of national and EU-level industrial policy. The United Kingdom's *Compute Roadmap* [34], the SRC/SIA *Decadal Plan for Semiconductors* in the United

States [35], the World Economic Forum and AI Governance Alliance analysis of China's AI industry transformation [36], the Chinese Academy of Sciences roadmap for Information Science & Technology to 2050 [37], the European Industrial Technology Roadmap for Cloud–Edge [3], and ECSO's *Strategic Vision: European Cybersecurity 2030* [38] illustrate this wider roadmap landscape. These documents address important areas such as compute capacity, semiconductor capability, AI industrialisation, cloud-edge coordination, and cybersecurity strategy. However, they do not provide a layered cybersecurity and cyber-resilience roadmap for the Cloud–Edge–IoT continuum. They also do not project capability-level transitions onto a regulation-aligned 2026–2040 horizon. This paper addresses that gap by linking architectural decomposition, capability clustering, sovereignty considerations, transition matrices, and implementation recommendations.

III. METHODOLOGY

The roadmap combines an architectural model, a strategic synthesis, an analytical template, and a temporal projection within a single three-stage research process, and the relationship between these elements is summarised in Fig. 1. The architectural plane defines what is secured: four execution environments, six vertical Security Layers, and four transversal Security Cross-Layers, each populated with capabilities that serve as the smallest traceable units of analysis. The synthesis plane consolidates these capabilities into three Priority Clusters that reflect coherent policy and engineering ambitions rather than independent verticals. The profiling plane applies a single seven-dimension template to each cluster, ensuring that baseline conditions, target outcomes, drivers, activities, enablers, disruptors, failsafes, and transversal objectives are reported on a comparable basis. The temporal plane projects each cluster through three roadmap phases, evaluated along four assessment perspectives, where each matrix additionally carries an ODS positioning row, an SovL positioning row, and a Critical Enabler row whose Phase 1 and Phase 2 cells name the gate condition for progression to the next phase.

The three stages therefore have distinct analytical functions. Stage 1 (Section IV) is a decompositional operation: it establishes the architectural vocabulary, exposes layer and cross-layer dependencies, and identifies the capabilities required within each part of the continuum. Stage 2 (Section V) is a synthetic operation: it aggregates capabilities that share dependencies or strategic outcomes into three coordination domains and analyses each through the seven-dimension template. Stage 3 (Section VI) is a projective operation: it embeds the cluster profiles in time through 2026–2040 transition matrices, exposing the sequencing of research, regulation, deployment, market uptake, Critical Enablers, phase-gate conditions, and shared bottlenecks. Rather than predicting when each milestone will occur, the methodology organises the capabilities, dependencies, and transition conditions that make progress plausible.

In this paper, *Sovereignty Level* denotes the extent to which

Methodological Flow: Stage 1 Architectural Decomposition → Stage 2 Priority Clustering and Seven-Dimension Synthesis → Stage 3 Phase Logic and Transition Matrices				
Plane	(A) Architecture	(B) Synthesis	(C) Profiling Lens	(D) Roadmap Projection
Role	Static model of what is secured across the continuum	Strategic grouping of capabilities into a small number of decision-relevant Priority Clusters	Uniform analytical template applied per Cluster	Temporal trajectory of each Cluster over 2026–2040
Units	6 Layers (vertical stack) and 4 Cross-Layers (transversal enablers), each decomposed into Capabilities (e.g., L1.1 Hardware Roots of Trust; L5.2 PQC), spanning four execution environments (HPC, Cloud, Edge, Devices)	3 Priority Clusters : Cluster 1 Sovereign Trusted Infrastructure; Cluster 2 Cognitive Security and Autonomous Cyber Defence; Cluster 3 Federated Operational Sovereignty	Seven-Dimensional Template : D1 Baseline; D2 High-Impact Activities and Target Outcomes; D3 Primary Drivers; D4 Catalysts and Enablers; D5 Disruptors and Systemic Risks; D6 Failsafe Mechanisms; D7 Transversal Meta-Layer	3 Phases (2026–2030; 2030–2035; 2035–2040) projected through 4 Perspectives (R&I Maturity; Policy, Regulation, and Standards; Operational Deployment and Adoption; Ecosystem Uptake and Strategic Impact). Each matrix also carries an ODS row, a SovL row, and a Critical Enabler row
Traceability	Each Capability maps to one or more Priority Clusters	Each Priority Cluster aggregates capabilities drawn from several Layers and Cross-Layers	Each Priority Cluster is profiled once using the same seven dimensions	Each Priority Cluster is projected once as a Transition Matrix; the Critical Enabler row chains Phase 1 → Phase 2 → Phase 3

Figure 1. Conceptual orientation map of the roadmap. The horizontal axis traces the three-stage methodological flow from architectural decomposition through priority clustering and seven-dimension synthesis to phase logic and transition matrices. Layers and Cross-Layers constitute the architectural model and are decomposed into traceable Capabilities; Priority Clusters carry the strategic synthesis; the seven-dimensional template profiles each Cluster along a uniform analytical schema; and the Transition Matrix projects each Cluster across three temporal Phases and four longitudinal Perspectives, with ODS, SovL, and the Critical Enabler as dedicated rows of the matrix.

critical capabilities and dependencies can be shaped, governed, assured, and operated under European influence or control. It is assessed at the capability and dependency level in Stage 1, used to interpret the strategic significance of priority clusters in Stage 2, and projected as a per-phase qualitative band in Stage 3 (the SovL row of each transition matrix). It is used as an interpretive strategic lens rather than as a rigid quantitative score.

a: Stage 1 Output: Architectural Decomposition and Capability Identification

Stage 1 decomposes the continuum into architectural vertical and cross-cutting layers. These layers are treated as analytically distinct but operationally interdependent: a vulnerability or governance gap at one layer typically propagates to adjacent layers, so effective security requires coordinated action across the vertical and horizontal extent of the architecture [6], [8]. For each layer, Stage 1 further identifies the constituent *capabilities*: the technical and operational sub-domains in which strategic investment, standardisation, and ecosystem building are required.

Stage 1 answers three questions:

- 1) Where are the major security and resilience problem domains within the continuum?
- 2) At which architectural layers do they emerge?
- 3) Which capabilities within each layer are sufficiently strategic, cross-cutting, or underdeveloped to justify dedicated roadmap attention?

Capabilities are derived from four sources: the architectural characteristics of distributed systems across HPC, cloud, edge, and device tiers; the recurring cybersecurity

challenges observed at those tiers (hardware integrity, software supply-chain verification, workload isolation, identity federation, data confidentiality, and perimeter control); cross-cutting strategic concerns (sovereignty, trust, interoperability, resilience, assurance, and regulatory alignment); and the need to connect technical architecture with operational constraints, governance requirements, and deployment pathways. A capability is therefore defined as a strategic ability that the European ecosystem should be able to design, deploy, govern, standardise, assure, coordinate, or scale in order to achieve trustworthy, resilient, and sovereign operation of the continuum. Capabilities may encompass technical controls, governance mechanisms, interoperability instruments, assurance functions, ecosystem coordination capacities, and deployment enablers.

The output of Stage 1 is a structured map of the problem space, organised into six Security Layers and four Transversal Security Cross-Layers, each populated with its constituent capabilities (see Section IV). Sovereignty-sensitive capabilities, where dependencies on external providers or assurance mechanisms are structurally significant, are identified so that Stage 2 can track their evolution.

b: Stage 2 Output: Priority Clustering and Seven-Dimension Analysis

Stage 2 groups the capabilities identified in Stage 1 into three Priority Clusters: (i) *Sovereign Trusted Infrastructure*, the hardware, cryptographic, software-update, data-protection, and resilience foundations that anchor trust across the continuum; (ii) *Cognitive Security and Autonomous Cyber Defence*, the AI-assisted operational layer that scales detection,

analysis, and response beyond human-paced workflows; and (iii) *Federated Operational Sovereignty*, the interoperability, supply-chain verification, assurance, and federation substrate that converts individually sovereign components into a unified European trust fabric.

The use of three priority clusters is a deliberate synthesis choice rather than an assertion that only three cybersecurity priorities exist. This is consistent with technology-roadmapping practice, where roadmaps function as strategic planning and communication instruments that organise complex technical trajectories into a smaller number of decision-relevant domains [39]. A roadmap may identify many relevant capabilities, but policy and funding coordination require higher-level priorities that communicate strategic direction, expose shared dependencies, and support portfolio-level decision-making. The three clusters therefore function as an executive structuring layer: they consolidate related capabilities into coherent investment and coordination domains while preserving the more granular capability analysis underneath.

Each priority cluster is analysed through a seven-dimension template applied consistently across the three clusters. The same template also preserves traceability to the underlying capabilities from which each cluster is derived:

- **(D1) Baseline**, describing the current state of the priority cluster, its capability maturity, dependencies, and main implementation gaps;
- **(D2) High-Impact Activities and Target Outcomes**, identifying the concrete research, innovation, standardisation, or deployment actions expected to advance the priority cluster, with each action assigned to a target phase and linked to the intended target outcome;
- **(D3) Primary Drivers**, identifying the threat and regulatory drivers that make the priority cluster urgent and non-deferrable;
- **(D4) Catalysts and Enablers**, identifying the funding instruments, regulatory and standardisation mechanisms, pilot infrastructures, and ecosystem coordination mechanisms that can accelerate the priority cluster;
- **(D5) Disruptors and Systemic Risks**, identifying technical cliffs such as the emergence of cryptographically relevant quantum computers, dependency risks such as supply-chain exposure and vendor lock-in, market concentration, and geopolitical constraints that could delay, weaken, or redirect the priority cluster;
- **(D6) Failsafe Mechanisms**, specifying fallback, isolation, rollback, redundancy, and graceful-degradation mechanisms that preserve security and resilience if the primary capability or deployment pathway is delayed, compromised, or only partially realised; and
- **(D7) Transversal Meta-Layer**, assessing how the priority cluster contributes to broader European strategic objectives, including sovereignty, trust and ethics, and sustainable security.

c: Stage 3 Output: Phase Logic and Transition Matrices

Stage 3 projects each priority cluster onto a three-phase transition matrix covering the 2026–2040 horizon. The phases are:

- **Phase 1: Near-Term Implementation and Pilot Actions (2026–2030)**, focused on deploying near-ready solutions, enforcing enacted regulation, validating early pilots, and closing immediate governance gaps. Regulatory instruments whose application dates fall within a phase window are treated as obligations of that phase, even where they bind during the phase rather than at phase entry;
- **Phase 2: Mid-Term Scale-Up, Industrial R&D and Standardisation (2030–2035)**, focused on industrialising sovereign capabilities, federating architectures, scaling validated pilots, and building the workforce and institutional infrastructure required for wider adoption; and
- **Phase 3: Long-Term Strategic Autonomy and Leadership (2035–2040)**, focused on achieving operational maturity, consolidating European leadership, advancing frontier research, and resolving long-term governance and oversight questions.

d: Assessment Perspectives

The content of each phase column is informed by four assessment perspectives. They are chosen because they jointly capture the distinct ecosystem conditions that must align for a cluster to progress, while remaining narrow enough to stay analytically tractable. Technical readiness alone does not predict adoption, regulatory obligation alone does not produce deployment, and deployment alone does not produce market viability. The four perspectives are therefore treated as concurrent rather than sequential:

- **R&I Maturity**, covering the technical maturity of the capabilities underlying the priority cluster, the maturity of their enabling dependencies, the availability of pilot deployments, and the readiness of the research and innovation ecosystem to support transition;
- **Policy, Regulation, and Standards**, covering the regulatory obligations that drive the priority cluster, the standards and certification mechanisms that support it, and the policy instruments that can accelerate or constrain adoption;
- **Operational Deployment and Adoption**, covering the availability of deployable solutions, the maturity of deployment pathways, and the readiness of users, operators, and infrastructure providers to adopt the priority cluster; and
- **Ecosystem Uptake and Strategic Impact**, covering the ecosystem conditions that shape adoption, the strategic significance of achieving the target state, and the consequences of delay or failure.

In the per-cluster transition matrices presented in Section VI (Tables 1–3), each of the four perspectives is realised

as a separate row, and the three phases as columns; each cell describes the observable state of the cluster under one perspective during one phase. The narrative cluster trajectories in Sections VI-A–VI-C expand the column-wise reading of each matrix into prose, focusing on what changes between phases.

e: Operational Deployment State (ODS) and Strategic Sovereignty Level (SovL) Rows

Each transition matrix uses two qualitative positioning rows to summarise the cluster status within each roadmap phase. The *ODS* row describes deployment breadth and operational maturity within the phase, using the fixed vocabulary *Applied R&D* → *Fragmented Piloting* → *Standardised Integration* → *Ubiquitous Operation*. The arrow notation in an ODS cell records the span of deployment states traversed during the phase rather than a single point estimate at phase entry; for example, *Applied R&D* → *Fragmented Piloting* indicates that the cluster moves from capability development and controlled experimentation toward project- or sector-level pilots within that phase. The *SovL* row uses the fixed vocabulary *High Foreign Dependency* → *Emerging EU Ecosystem* → *Full Sovereign Autonomy*. The SovL row operationalises, at the cluster level and per phase, the same Sovereignty Level construct introduced as an interpretive lens in Section III: it is the per-phase expression of that lens, not an independent metric. Both rows are presented above the four perspective rows in each matrix, so that the ODS and SovL position of the cluster can be read directly from the matrix without re-deriving it from the perspective cells. Where a cluster combines capabilities with different sovereignty profiles, the SovL cell provides a high-level indication of the resulting intra-cluster variation.

f: Critical Enabler Row

The *Critical Enabler* row is the phase-gate row of each transition matrix. It names, for each roadmap phase, the condition whose delivery determines whether progression across the relevant phase boundary is plausible. Throughout the paper, *phase gate* refers to the checkpoint between two consecutive roadmap phases, and *gate condition* denotes the condition whose delivery controls that checkpoint. Each phase column therefore terminates in a *Critical Enabler* cell, presented as the bottom row of the matrix. For Phase 1 and Phase 2, the Critical Enabler identifies the named gate condition, or tightly coupled set of conditions treated jointly, whose absence would block plausible progression of the cluster to the next phase. For Phase 3, which is the final phase within the 2026–2040 roadmap horizon, the Critical Enabler row records the consolidation condition for the 2040 target state rather than a gate to a subsequent phase.

IV. STAGE 1 OUTPUT: CLOUD–EDGE–IOT LAYERS AND CAPABILITIES

Building on the methodological separation introduced in Section III, Stage 1 defines the architectural plane of the roadmap. The continuum is modelled as a layered reference

Execution environments			
HPC	Cloud	Edge	Devices
L6: Network and Perimeter			
L5: Data-Centric (PQC, TEE, QKD, /SMPC)			
L4: User and Orchestration (ZT, IAM, PAM)			
L3: Application (Workloads, APIs)			
L2: Software (OS, Middleware, OTA)			
L1: Hardware (RoT, PhySec)			
CL1: Cyber-Resilient SW/AI Lifecycle			
CL2: Dynamic Risk and SecOps			
CL3: Interoperability (Simpl, CAMARA, MIMs)			
CL4: Compliance-by-Design and Assurance			

Figure 2. Layered security framework. Four execution environments (HPC, Cloud, Edge, Devices) span six vertical Security Layers (L1–L6) and four horizontal Transversal Security Cross-Layers (CL1–CL4). The vertical stack is presented from the lowest trust anchor upwards.

architecture spanning four execution environments (HPC, Cloud, Edge, Devices) and organised into six *Security Layers* forming the vertical stack and four *Transversal Security Cross-Layers* acting as horizontal enablers, as shown in Fig. 2. HPC refers to infrastructure for large-scale scientific and AI training capacity; Cloud offers elastic service hosting and orchestration; Edge brings computation closer to users, industrial sites, telecom infrastructure, and data sources; and Devices include resource-constrained sensors, actuators, embedded systems, and IoT endpoints operating closest to the physical world. The decomposition aligns with established reference architectures, including ETSI MEC GS 003 [25], NIST SP 800-207 and SP 800-207A for ZT [4], [5], NIST CSF 2.0 [40], ISO/IEC 27400 [41], and the ENISA baseline for IoT [42], and is consistent with the distributed computing-continuum framing in recent literature [1], [2] and in the European industrial technology roadmap for the next-generation cloud-edge [3].

The layers are analytically distinct but operationally interdependent: gaps at one layer can propagate to adjacent layers, as documented in the edge-computing security literature [6]–[8]. The model provides the shared vocabulary used throughout the paper and exposes cross-layer dependencies, allowing the priority clusters in Section V and the transition matrices in Section VI to be analysed as an interconnected portfolio rather than as isolated priorities. The EU cybersecurity certification framework [18] and its EUCC operationalisation [19] provide the regulatory anchoring for several of the capabilities defined below.

The remainder of this section introduces each layer and cross-layer and summarises its constituent capabilities. The full capability catalogue, including layer or cross-layer codes and principal references, is provided in Appendix as Table 4. These capabilities are treated as atomic analytical units that are aggregated into the three priority clusters analysed in Section V.

A. SECURITY LAYERS (VERTICAL STACK)

The six Security Layers define the vertical stack of the continuum, moving from physical and silicon-level trust foundations through software, applications, identity and orches-

tration, data protection, and the network infrastructure. They are presented from the lowest trust anchor upwards because weaknesses at lower layers can undermine guarantees provided by higher layers, while higher-layer controls are required to operationalise security, governance, and resilience across distributed environments.

1) Layer 1: Hardware-Centric Security

Layer 1 addresses the physical and silicon-level trust foundations of the continuum and provides the verifiable anchors on which higher-layer security assurances depend. It covers hardware roots of trust, secure boot, remote attestation, Trusted Platform Modules, Physical Unclonable Functions, and physical-layer detection primitives [26], [27]. Without a verifiable silicon anchor, software-level attestation and cryptographic identity rest on assumptions that are difficult to validate in distributed and physically exposed environments. Layer 1 is the principal regulatory locus of hardware sovereignty in the continuum, and the layer at which EUCC “High” certification of secure elements and hardware roots of trust is most directly applied [19].

Capability L1.1, Hardware Roots of Trust. Cryptographically verifiable device and supply-chain integrity from fabrication to deployment, with a strategic focus on advancing European open-hardware designs (RISC-V) toward EUCC “High” assurance. Technical foundations derive from TPM 2.0 [26] and integrity measurement architectures [27]. European instances include OpenTitan [43], Keystone [44], and the DARE SGA1 RISC-V initiative [45].

Capability L1.2, Physical-Layer Threat Detection and Fingerprinting. Exploitation of two complementary classes of physical-layer features: (i) channel-intrinsic observables, including Channel State Information (CSI), Carrier Frequency Offset (CFO), and Received Signal Strength Indicator (RSSI); and (ii) transmitter-intrinsic Radio Frequency Fingerprinting (RFF) arising from device-specific hardware impairments such as I/Q imbalance, power-amplifier non-linearity, and oscillator phase noise. Together these enable real-time device authentication and anomaly detection at the lowest communication layer, complementing upper-layer cryptographic protections and providing identity assurance for resource-constrained devices that cannot reliably execute conventional authentication protocols [6], [8]. Operational deployment of RFF at the European edge, however, is gated by two coupled trustworthiness challenges: feature drift under temporal, thermal, and propagation-environment variation, which degrades classifier accuracy over the device lifecycle; and the privacy exposure inherent to persistent, non-revocable hardware-level identifiers, which engages GDPR Article 25 (data protection by design and by default) and motivates privacy-preserving RFF pipelines as a precondition for deployable physical-layer security [46].

2) Layer 2: Software-Centric Security

Layer 2 secures the software substrate on which continuum workloads execute, including hypervisors, container

runtimes, distributed operating systems, and the pipelines that maintain them. Its central concerns are attack-surface reduction through OS and middleware hardening, and cryptographically verified, failure-resilient software distribution to field-deployed nodes for which physical access for remediation is limited or infeasible [47], [48]. Assurance at Layer 2 is necessary for trustworthy execution of the services and workloads built above it.

Capability L2.1, OS and Middleware Hardening. Security hardening of hypervisors (KVM/QEMU), container runtimes, and distributed operating systems, with emphasis on sovereign, lightweight Linux distributions optimised for edge resource constraints and reduced attack surface, in line with DevSecOps and ZT guidance [4], [9].

Capability L2.2, Secure OTA Patch and Update Management. Cryptographically verified, failure-resilient update pipelines for field-deployed edge nodes such as smart grids, Open Radio Access Network (O-RAN) radios, industrial gateways, vehicles, and IoT devices, including over-the-air and other remotely managed update gateways. The IETF SUIT architecture [47] and the Uptane standard [48] provide the main reference frameworks.

3) Layer 3: Application-Centric Security

Layer 3 protects the workloads and service interfaces executing across the continuum, including containerised applications, serverless functions, service meshes, and the APIs that expose them. Application-layer defences are a key enforcement point for obligations that surface as runtime behaviours rather than infrastructure properties, including AI Act [16] and GDPR Article 25 [29] requirements. The NIST SP 800-204 microservices security series [9], [49], [50] and the OWASP API Security Top 10 [51] provide the main reference controls.

Capability L3.1, Workload Security. Securing containerised applications and serverless functions through hardened service meshes and sidecar proxies that provide mutual TLS, traffic policy enforcement, and granular inspection while preserving operational performance, aligned with NIST SP 800-204 [49] and SP 800-204A [50].

Capability L3.2, In-Band Network Telemetry and Deep Observability. Embedding telemetry directly into packets or service-mesh flows traversing containerised workloads, enabling real-time security monitoring and anomaly detection without exclusive reliance on dedicated out-of-band monitoring infrastructure [49], [50].

Capability L3.3, API Security Gateway and Policy Enforcement. A unified enforcement point for authentication tokens, rate limiting, schema validation, and payload inspection, increasingly important as containerised and AI-enabled workloads communicate through REST and gRPC APIs. This capability follows the OWASP API Security Top 10 taxonomy [51] and the DevSecOps-for-service-mesh guidance in NIST SP 800-204C [9].

4) Layer 4: User and Orchestration-Centric Security

Layer 4 governs identity, access, and policy enforcement across the multi-provider continuum. It implements continuous, context-adaptive authorisation aligned with NIST SP 800-207 [4] and its cloud-native extension SP 800-207A [5]; federated and self-sovereign identity for humans, machines, and autonomous workloads based on the W3C Verifiable Credentials Data Model [52] and, in Europe, the European Digital Identity Regulation 2.0 (eIDAS 2.0) framework [53] and the European Digital Identity Wallet (EUDI) under successive implementing acts [54], [55]; and privileged-access controls that reduce reliance on standing credentials. Layer 4 is the layer at which identity-centric and policy-driven controls substitute for assumptions of stable network perimeter control.

Capability L4.1, ZT Orchestration. Policy Enforcement Point and Policy Decision Point architectures that enable continuous authorisation and dynamic access controls adapted to request context, device posture, workload identity, and operational risk, aligned with NIST SP 800-207 [4] and its cloud-native extension [5].

Capability L4.2, Federated Identity and Access Management. Federated and self-sovereign identity mechanisms enabling cryptographically verifiable, decentralised authentication of machines, users, and automated workloads across heterogeneous cloud-edge domains, based on the W3C Verifiable Credentials Data Model [52] and, in Europe, the eIDAS 2.0 framework [53] and the EUDI Wallet under successive implementing acts [54], [55]. The eIDAS 2.0 framework and the EUDI Wallet provide a legal and technical basis for natural- and legal-person identity at European scale; their use as a federation primitive for machine identity, workload identity, and cross-provider Single Sign-On (SSO) in cloud-edge Identity and Access Management (IAM) requires integration with hardware attestation (Capability L1.1), ZT orchestration (Capability L4.1), and policy enforcement (Capability CL3.1).

Capability L4.3, Privileged Access Management (PAM) and Just-In-Time Access. Reduction of over-provisioned standing privileges, a recurring enabler of advanced persistent threat campaigns, by replacing permanent access with time-bounded, contextually justified, and auditable grants, consistent with ZT authorisation principles [4], [5].

5) Layer 5: Data-Centric Security

Layer 5 protects data across the continuum lifecycle: at rest, in transit, and in use. It spans confidential computing through Trusted Execution Environments [56]; post-quantum cryptography based on NIST FIPS 203/204/205 [57]–[59]; signalling and data-plane protection; distributed reputation and trust; Quantum Key Distribution (QKD) for selected high-value links [60], [61]; and Secure Multi-Party Computation (SMPC) for collaborative processing across mutually distrusting parties. Layer 5 is the layer at which GDPR Article 32 [29] and AI Act Article 15 [16] obligations on

confidentiality, integrity, and robustness are most directly operationalised.

Capability L5.1, Hardware-Isolated Confidential Computing. Protection of data *in use* through Trusted Execution Environments (TEEs) spanning the cloud-to-IoT data path, including Intel TDX, AMD SEV-SNP, ARM CCA, and the open RISC-V Keystone framework [44], as scoped by the Confidential Computing Consortium [56]. TEEs deliver near-native performance under a hardware-rooted trust assumption, anchored in Capability L1.1 (Hardware Roots of Trust) for remote attestation and providing the execution substrate for privacy-preserving computation (Capability L5.6) when cryptographic-only approaches are infeasible on resource-constrained edge nodes.

Capability L5.2, Post-Quantum Cryptography (PQC). Migration to quantum-resistant algorithms, namely Module-Lattice-Based Key-Encapsulation Mechanism (ML-KEM) [57], Module-Lattice-Based Digital Signature Algorithm (ML-DSA) [58], and Stateless Hash-Based Digital Signature Algorithm (SLH-DSA) [59], including adaptations for resource-constrained devices exposed to long-term “Harvest Now, Decrypt Later” threats. This capability is complemented by ETSI TS 103 744 hybrid key-exchange profiles [62] and aligned with the NIS CG PQC roadmap [13].

Capability L5.3, Signalling and Data-Plane Security. Embedding cryptographic authentication and integrity protection into signalling, control-plane, and data-plane interactions, beyond best-effort packet forwarding, in alignment with 3GPP TS 33.501 [63], O-RAN security specifications [64], [65], and the SNS JU SRIA [66].

Capability L5.4, Distributed Reputation and Trust Networking. Distributed reputation and trust mechanisms, potentially supported by Distributed Ledger Technology and smart contracts, enabling decentralised trust evaluation across heterogeneous providers without reliance on a single governance point, and aligned with Simpl federation interfaces [18], [67]–[69].

Capability L5.5, Quantum Key Distribution (QKD) for Critical Links. Information-theoretically secure key exchange over optical fibre for selected point-to-point high-value links, such as government communications and critical infrastructure backbones, complementing algorithmic PQC for link-layer protection and governed by ETSI GS QKD 004 [61] and GS QKD 014 [60]. QKD is treated here as a complement to algorithmic PQC, not a substitute for it.

Capability L5.6, Privacy-Preserving Computation. Cryptographic mechanisms enabling computation over confidential data without disclosing inputs to computing parties, comprising (i) SMPC, allowing mutually distrusting parties to jointly evaluate functions over combined private inputs, with foundations in the threshold-cryptography lineage formalised by NIST [70], and (ii) Homomorphic Encryption (HE), permitting computation directly on ciphertexts under schemes including BFV, BGV, and CKKS, standardised under ISO/IEC 18033-6 [71] and the HomomorphicEncryp-

tion.org community specification [72]. The two mechanisms are complementary: SMPC offers cryptographic guarantees for collaborative computation at the cost of interactive protocols and communication overhead, while HE enables computation directly on encrypted data with computational overhead that depends on the circuit depth, scheme parameters, and implementation choices. Together they extend confidential computing (Capability L5.1) beyond single-party workloads to federated analytics across European providers and jurisdictions, satisfying GDPR Articles 25 and 32 on data-protection-by-design and security of processing [29] and AI Act Article 10(5) on appropriate safeguards for processing special-category data in bias monitoring [16].

6) Layer 6: Network Infrastructure and Perimeter-Centric Security

Layer 6 secures the communication fabric of the continuum, including 5G and 6G cores, disaggregated RAN, IT/OT gateways, far-edge compute, and non-terrestrial network segments. It aligns with 3GPP TS 33.501 [63], O-RAN WG11 security specifications [64], ZT for O-RAN [65], the SNS JU SRIA [66], and 3GPP NTN security [73], [74]. It is the layer at which cybersecurity intersects most directly with physical resilience, because failures or compromises in the communication fabric can cascade into operational disruption, safety hazards, or kinetic effects in critical infrastructures [6], [8].

Capability L6.1, Telco-Cloud and O-RAN Security. Hardening of distributed 5G and 6G cores and RAN components in alignment with 3GPP TS 33.501 [63], O-RAN WG11 security specifications [64], ZT for O-RAN [65], and the SNS JU SRIA [66], with emphasis on secure network slice isolation, virtualised RAN protection, and sovereign operational control over critical telecom infrastructure.

Capability L6.2, Physical Resilience and Safety. IT/OT gateway security for high-availability edge environments such as smart grids, transport systems, and manufacturing sites, reducing the risk that digital breaches cascade into operational disruption, kinetic damage, or safety hazards [6], [8], [63], [66].

Capability L6.3, Edge-Native Autonomous Guardians. Lightweight, localised security control functions, including Security-as-a-Service aggregators, hosted directly at far-edge gateways or within Open-RAN Radio Intelligent Controllers (xApps/rApps) to enable autonomous enforcement at the network periphery [64]–[66].

Capability L6.4, Non-Terrestrial Network and Satellite Security. Security requirements for integrating satellite and non-terrestrial network segments into 6G architectures for coverage continuity, backhaul resilience, and emergency operations, aligned with 3GPP NTN specifications [73], [74] and the EU Space Programme.

B. TRANSVERSAL SECURITY CROSS-LAYERS

The four Transversal Security Cross-Layers define horizontal security capabilities that span the vertical stack and address properties no single layer can provide on its own: lifecycle in-

tegrity of software and AI components, operational response capacity, interoperability across providers and jurisdictions, and continuous regulatory assurance.

1) Cross-Layer 1: Automated Security Processes and Cyber-Resilient AI Lifecycle

Cross-Layer 1 spans the lifecycle of software and AI component security, from secure development and integration to runtime supply-chain verification and continuous adversarial validation. It treats AI systems both as defensive instruments and as attack targets, the latter framing being required by AI Act Article 9 risk-management obligations for high-risk systems [16]. CL1 aligns with service-mesh DevSecOps patterns [9], the NIST AI Risk Management Framework and its Generative AI Profile [75], [76], OWASP guidance on Large Language Model (LLM) and API security [51], [77], the SLSA provenance framework [78], and the adversarial robustness literature [79], with the objective of embedding cyber-resilience into how software and AI components are designed, built, shipped, verified, and tested rather than treating assurance as a post-deployment activity.

Capability CL1.1, Continuous DevSecOps. AI-assisted code analysis, vulnerability detection, and remediation integrated into the earliest stages of the software lifecycle, following NIST SP 800-204C [9].

Capability CL1.2, Model Integrity and DataBOMs. Protection of AI training and deployment pipelines against data poisoning, unauthorised model manipulation, and insufficient traceability of training data and model artefacts, aligned with the NIST AI Risk Management Framework [75], its Generative AI Profile [76], and OWASP LLM security guidance for application-facing model risks [77], and supporting AI Act Article 9 risk-management requirements [16].

Capability CL1.3, Dynamic Supply-Chain Verification and Runtime SBOMs. Dynamic Software Bills of Materials and cryptographic proof-of-execution mechanisms that continuously verify the integrity of containerised microservices and AI components as they migrate across the multi-provider continuum, supported by the SLSA provenance framework [78].

Capability CL1.4, Automated Adversarial Testing and Continuous Purple Teaming. Continuous automated penetration testing, coverage-guided and protocol-level fuzzing, prompt-injection and insecure-output validation for LLM-enabled services, and purple-team automation against live or staging environments, providing the adversarial validation counterpart to DevSecOps and grounded in the adversarial robustness literature and OWASP application-security guidance [51], [77], [79].

2) Cross-Layer 2: Dynamic Risk Management and Operational Cyber Resilience

Cross-Layer 2 governs threat detection, analytics, cyber threat intelligence, and operational response across the continuum. It supports Security Operations Centre (SOC) federation across Member States [80], integrates AI-native teleme-

try analytics via the 5G Network Data Analytics Function (NWDAF) architecture [81] and LLM-assisted security operations, and structures the cyber threat intelligence lifecycle using MITRE ATT&CK [82] and STIX/TAXII 2.1 [83], [84] as the structured- Cyber Threat Intelligence (CTI) foundation, complemented by ENISA threat landscape reporting [85]. Its role is to reduce detection-to-response timelines and improve coordinated operational resilience in environments where human-paced analysis alone is insufficient.

Capability CL2.1, Automated SOC and Collaborative Threat Intelligence. Federated SOC and collaborative threat-intelligence mechanisms across Member States, supported by legally protected sharing platforms that reduce institutional trust barriers and enable coordinated situational awareness [80].

Capability CL2.2, High-Precision Telemetry and Security Signalling. High-fidelity telemetry and security signalling mechanisms that feed real-time threat-intelligence and detection pipelines while managing bandwidth, latency, and alert-volume constraints, integrating with 5G NWDAF analytics interfaces [81] and threat-landscape baselines [85].

Capability CL2.3, Internet of Behaviour and Evidence Sharing. Collection, correlation, and sharing of behavioural evidence across infrastructure components to detect anomalous patterns invisible to purely signature-based defences, structured through MITRE ATT&CK [82] and STIX/TAXII 2.1 [83], [84] and informed by ENISA threat reporting [85].

Capability CL2.4, AI-Native Analytics Integration (NWDAF and LLMSecOps). Integration of cybersecurity telemetry with 5G NWDAF analytics [81] and LLM-assisted security operations to support triage, correlation, investigation, and response, framed by the NIST AI RMF and its Generative AI Profile [75], [76] and complemented by OWASP LLM guidance for application-facing risks such as prompt injection, sensitive-information disclosure, and insecure output handling [77].

Capability CL2.5, Cyber Threat Intelligence Lifecycle Management. Governance of the CTI lifecycle as a prerequisite for federated SOC operation, using MITRE ATT&CK [82] and STIX/TAXII 2.1 [83], [84], complemented by ENISA threat landscape reporting [85].

Capability CL2.6, Deception Technology and Active Defence. Deployment of decoy assets, including honeypots, honeynets, credential canaries, and fake API endpoints, to generate high-fidelity alerts based on adversary interaction and to support earlier detection of lateral movement or reconnaissance [82], [85].

3) Cross-Layer 3: Interoperable Security Mechanisms and Open-Source Verifiability

Cross-Layer 3 enables secure interoperation across heterogeneous providers, infrastructures, and jurisdictions. It anchors federation in the Simpl open-source middleware for Common European Data Spaces [67], CAMARA Network APIs for pan-European compute federation [86], semantic inter-

operability through OASC Minimal Interoperability Mechanisms [68] and the ETSI NGSI-LD API [69], and federated cyber ranges for shared validation infrastructure. Its objective is to convert individually sovereign components into a collectively sovereign European trust fabric while avoiding new forms of vendor lock-in.

Capability CL3.1, Heterogeneous Interoperability and Simpl Integration. Alignment with the Simpl open-source smart middleware [67] to support secure federated access, policy portability, and interoperability across Common European Data Spaces, with semantic anchoring in OASC MIMs [68] and the ETSI NGSI-LD API [69].

Capability CL3.2, Neutral Host and Multi-Tenant Isolation. Enforcement of ZT edge operations across network partitions, tenants, and shared-infrastructure models, ensuring that infrastructure sharing does not imply implicit trust between operators or workloads [4], [5].

Capability CL3.3, Pan-European NaaS Federation and Cross-Border Edge Roaming. Standardised interfaces leveraging CAMARA Network APIs [86] to support a federated Network-as-a-Service (NaaS) model for cross-border edge and connectivity services, in alignment with the Digital Networks Act (DNA) proposal [87].

Capability CL3.4, Semantic Security Interoperability. Common ontologies and data models for security events, asset taxonomies, policy attributes, and risk classifications, operationalised through OASC Minimal Interoperability Mechanisms [68] and the ETSI NGSI-LD API [69].

Capability CL3.5, Cyber Range and Digital Twin Federation. Federation of national cyber ranges and digital-twin environments into shared EU-wide validation infrastructure for testing cross-provider security, resilience, and interoperability assumptions, building on EU certification frameworks [18], CONCORDIA outputs [80], and the European industrial cloud-edge roadmap [3], and aligned with the Cyber Solidarity Act.

4) Cross-Layer 4: Compliance-by-Design, Agile Governance and Automated Assurance

Cross-Layer 4 embeds regulatory compliance, governance, and assurance considerations into technical architecture. It operationalises continuous assurance for cloud services (ECCC for Cloud Services, when adopted) and edge products (EUCC) [18], [19] through machine-readable control catalogues and assessment results based on NIST OSCAL [88], [89]; cryptographic key management across multi-provider operations; privacy-preserving federated computation satisfying GDPR Article 25 [29]; cyber risk quantification that translates technical posture into financial and operational risk language under NIS2 [14], DORA [17], and NIST CSF 2.0 [40]; and AI trustworthiness and algorithmic accountability for autonomous security decisions under AI Act Article 9 [16], aligned with the NIST AI RMF [75]. Its objective is to shift assurance from point-in-time audit towards continuous, evidence-based, and telemetry-supported verification.

Capability CL4.1, Post-Quantum Readiness and ZT Architectures. Continuous ZT verification and post-quantum readiness embedded into cloud-edge infrastructure, aligned with NIST SP 800-207 [4] and SP 800-207A [5] and with FIPS 203/204/205 algorithm selection [57]–[59].

Capability CL4.2, Continuous Automated Certification. Lifecycle certification tracking for cloud services (ECCC for Cloud Services, when adopted) and edge products (EUCC) [18], [19], operationalised through machine-readable control catalogues, assessment artefacts, and evidence exchange using NIST OSCAL [88], [89].

Capability CL4.3, Multicloud Key Management as a Service. Cryptographic key, policy, and lifecycle management across dynamic multi-provider computing-continuum operations, integrating ZT authorisation [4], [5] with PQC algorithm selection [57]–[59].

Capability CL4.4, Cross-Jurisdictional Federated AI Governance. Governance and orchestration pattern for AI training and inference over distributed private datasets held across European jurisdictions and providers, combining federated learning with the privacy-preserving computation primitives of Capability L5.6 (SMPC, HE) and the hardware-isolated execution substrate of Capability L5.1 (TEEs) to enforce data minimisation, purpose limitation, and confidentiality at the protocol level rather than through contractual controls alone. This capability addresses the governance, attestation, and audit dimensions that the underlying primitives do not themselves provide: participant onboarding, model-update provenance, and differential-privacy budget accounting. It supports GDPR Article 25 on data-protection-by-design [29], AI Act Article 10 on data governance for high-risk AI systems [16], and the Data Act’s interoperability mandates for cross-border data spaces [28].

Capability CL4.6, Cyber Risk Quantification and Board-Level Reporting. Translation of technical security posture into financial, operational, and strategic risk language for decision-makers, aligned with NIS2 governance obligations [14], DORA [17], and NIST CSF 2.0 governance functions [40].

Capability CL4.7, AI Trustworthiness and Algorithmic Accountability. Assurance that AI systems making or supporting autonomous security decisions remain robust, accountable, and auditable, in compliance with AI Act Article 9 [16] and aligned with the NIST AI RMF and Generative AI Profile [75], [76].

V. STAGE 2 OUTPUT: PRIORITY CLUSTERING AND SEVEN-DIMENSION SYNTHESIS

Stage 2 consolidates the layer and cross-layer capabilities identified in Section IV into three priority clusters and analyses each through the seven-dimension template defined in Section III. The synthesis here is *capability-anchored and time-invariant*: it establishes why the priorities cohere, which capabilities they aggregate, which dependencies they share, and which strategic outcomes they target. Progression of these clusters is addressed separately in Section VI, while the corre-

Capability	C1	C2	C3	Role
L1.1 Hardware RoT	●		○	C1 primary; attestation anchor for C3
L1.2 PHY threat detection	●			C1 only
L2.1 OS/middleware	●			C1 only
L2.2 Secure OTA	●			C1 only
L4.1 Zero Trust orch.		●	●	C2/C3 shared enforcement
L4.2 Federated IAM/SSI			●	C3 only (identity primitive)
L5.1–L5.6 Data-centric	●			C1 only
L6.1 Telco-cloud/O-RAN	●	○	○	C1 primary; telemetry for C2; NaaS for C3
L6.2–L6.4 Network resil.	●			C1 only
CL1.2–CL1.4 AI lifecycle		●		C2 only
CL1.3 Runtime SBOMs	○		●	C1/C3 supply-chain bridge
CL2.1–CL2.6 SecOps/CTI		●		C2 only
CL3.1–CL3.5 Interop/fed.			●	C3 only
CL4.2 Continuous cert.			●	C3 only
CL4.4 Federated AI gov.			●	C3 only
CL4.7 AI accountability		●		C2 only

● primary cluster; ○ shared/bridge capability.

Figure 3. Capability-to-cluster mapping. Filled discs mark each capability’s primary cluster; open discs mark shared bridges (L4.1 between C2/C3; L6.1 across all three; CL1.3 between C1/C3). C1 = Sovereign Trusted Infrastructure; C2 = Cognitive Security and Autonomous Cyber Defence; C3 = Federated Operational Sovereignty.

sponding implementation recommendations are presented in Section VII. Where relevant, the analysis below refers to the underlying layer or cross-layer capabilities from which each cluster is derived.

A. CLUSTER 1: SOVEREIGN TRUSTED INFRASTRUCTURE

Cluster 1 consolidates the capabilities that provide the trusted execution substrate of the continuum: hardware roots of trust and physical-layer assurance (L1.1–L1.2), secure software foundations and secure OTA update mechanisms (L2.1–L2.2), confidential computing and data-in-use protection (L5.1), post-quantum cryptographic agility and lightweight security for constrained environments (L5.2 and L5.5–L5.6), signalling and data-plane integrity (L5.3), and resilience mechanisms for critical network infrastructure (L6.1–L6.4). Federated policies and autonomous defence can be trusted operationally only when the underlying hardware, software, cryptographic, and resilience foundations are sufficiently mature. The substrate must support hardware integrity through verifiable silicon roots of trust, quantum-resistant confidentiality through crypto-agile schemes aligned with FIPS 203/204/205, and autonomous resilience under network or orchestration-plane compromise. The shared critical dependency is European sovereign fabrication capacity under the EU Chips Act [90], [91].

a: D1 Baseline.

At the hardware and physical-layer security level (L1.1–L1.2), EU-headquartered designers, including Infineon, NXP, and STMicroelectronics, achieved EUCC “High” certification for proprietary secure-element families in 2025 [31]. However, fabrication of these components remains dependent

on non-EU foundries, and no EU-origin RISC-V processor has received EUCC or Common Criteria certification. At the software and update layer (L2.1–L2.2), field-deployed edge infrastructure remains dependent on heterogeneous hardening practices and update mechanisms. At the data-centric layer (L5.1–L5.6), edge and IoT environments remain dependent on classical cryptography and non-European TEE families, and extreme-edge devices remain constrained in compute, energy, and memory. The NIS Cooperation Group roadmap [13] provides binding migration milestones for quantum-resistant cryptography. At the network infrastructure layer (L6.1–L6.4), current deployments often assume persistent connectivity and central orchestration.

b: D2 High-Impact Activities and Target Outcomes.

Activities aggregate around four target outcomes whose evolution across phases is analysed in Section VI. The first outcome is European sovereign hardware roots of trust certified to EUCC “High”, advanced through RISC-V secure-element design (L1.1), supported by Chips JU pilot lines, and validated through OpenTitan [43], Keystone [44], and the DARE SGA1 EuroHPC initiative [45]. The second outcome is a quantum-resilient and crypto-agile continuum combining FIPS 203/204/205 [57]–[59] algorithms, ETSI TS 103 744 hybrid key-exchange profiles [62], lightweight cryptography for constrained nodes, confidential computing through hardware-isolated TEEs (L5.1), QKD for selected critical links (L5.5), and privacy-preserving collaborative computation through SMPC and HE (L5.6). The third outcome is resilient field-deployed software and update infrastructure (L2.1–L2.2), grounded in cryptographically verified, failure-resilient update pipelines for edge nodes that are physically remote or otherwise difficult to remediate. The fourth outcome is autonomous Island Mode operation across critical network infrastructure (L6.1–L6.4), aligned with the SNS JU SRIA [66] and validated under 3GPP/ETSI fallback profiles, ensuring that essential services continue to operate during disruption to connectivity or central orchestration.

c: D3 Primary Drivers.

The primary threat drivers for this cluster arise from attacks against the trusted execution substrate itself: state-sponsored exploitation of hardware access paths, including debug and test interfaces, side-channel leakage, fault-injection vectors, and physical tampering against field-deployed nodes (L1.1–L1.2); supply-chain insertion and compromised update paths affecting software and firmware maintenance (L2.1–L2.2); “Harvest Now, Decrypt Later” campaigns targeting long-lived data confidentiality and cryptographic migration gaps (L5.1–L5.6); and cascading failures caused by cyberattacks, geopolitical disruption, or other system-level disruptions affecting communication and orchestration infrastructure (L6.1–L6.4). The regulatory drivers are correspondingly distributed across the underlying capabilities: CRA Articles 10–11 establish cybersecurity and vulnerability-handling obligations [15]; NIS2 Article 21(2)(e) requires policies and

procedures for cryptography and encryption [14]; AI Act Articles 9 and 15 create risk-management, accuracy, robustness, and cybersecurity obligations for high-risk AI systems [16]; the NIS CG PQC roadmap defines the migration milestones for quantum-resistant cryptography [13]; DORA Article 11 requires ICT business continuity and disaster recovery capabilities [17]; and the SNS JU SRIA frames resilience as a core requirement for future 6G infrastructures [66].

d: D4 Catalysts and Enablers.

The main catalysts for this cluster map directly to the trusted-substrate capabilities. For hardware roots of trust and physical-layer assurance (L1.1–L1.2), the principal enablers are the EU Chips Act pilot lines, including NanoIC, FAMES, APECS, PIXEurope, and WBG [90]; the DARE SGA1 EuroHPC initiative [45]; CEN/CENELEC JTC 13 hardware-security standardisation; and EUCC “High” certification pathways. For secure software foundations and update mechanisms (L2.1–L2.2), relevant enablers include ECCC Strategic Agenda priorities [92], secure update frameworks, and coordinated pilot infrastructures for edge and critical-infrastructure deployments. For post-quantum cryptographic agility, confidential computing, QKD, and privacy-preserving computation (L5.1–L5.6), the primary enablers are NIST FIPS 203/204/205 [57]–[59], ETSI TS 103 744 hybrid key-exchange profiles [62], the NIS CG PQC roadmap, and confidential-computing and data-space pilots. For network resilience and Island Mode capabilities (L6.1–L6.4), SNS JU 6G resilience projects [66], 3GPP/ETSI standardisation, and cross-border 5G/6G testbeds provide the main transition infrastructure.

e: D5 Disruptors and Systemic Risks.

The main systemic risks affect different parts of the trusted execution foundation. For hardware roots of trust (L1.1), the principal disruptor is EU Chips Act fabrication-capacity shortfall [91]. For physical-layer assurance and constrained edge security (L1.2), energy, memory, and signal-quality constraints may limit the deployability of lightweight authentication, while feature drift over the device lifecycle and the privacy exposure of persistent, non-revocable hardware-level identifiers further constrain operational RFF deployment and engage GDPR Article 25 considerations. For secure software stack and secure remote/OTA update mechanisms (L2.1–L2.2), the main risks are heterogeneous legacy stacks, incomplete asset inventories, and insufficiently resilient update paths in Operational Technology (OT) and field-deployed edge environments. For data-centric security (L5.1–L5.6), early arrival of a Cryptographically Relevant Quantum Computer (CRQC) before migration is complete, PQC computational overhead on battery-powered IoT devices, side-channel advances against current TEE architectures, and incomplete cryptographic inventories of legacy OT/IoT systems could delay transition. For network resilience (L6.1–L6.4), dependencies on central orchestration, telecom supply-chain con-

centration, and insufficiently validated fallback modes could weaken Island Mode readiness.

f: D6 Failsafe Mechanisms.

Failsafe mechanisms should preserve security and continuity when parts of the trusted substrate are delayed, compromised, or only partially available. For hardware and physical-layer capabilities (L1.1–L1.2), these include redundant trust anchors, layered lightweight cryptography, physical-layer fallback signals for constrained devices, and tamper-resistant local decision logic. For secure software stack and OTA update mechanisms (L2.1–L2.2), the main failsafes are staged rollout, rollback, secure recovery partitions, and autonomous node quarantine via eBPF network policy when attestation or update verification fails. For data-centric security (L5.1–L5.6), the relevant failsafes are TEE abstraction layers to avoid vendor lock-in during the dependency period; HE and SMPC for privacy-preserving processing where workload latency and overhead constraints permit, particularly where workloads must temporarily execute on non-sovereign or lower-trust infrastructure; hybrid cryptographic schemes combining classical and PQC mechanisms for backward compatibility and harvest resistance; and crypto-agility frameworks enabling rapid algorithm replacement. For network resilience and Island Mode (L6.1–L6.4), failsafes include segmented autonomy zones, redundant local control paths, fallback routing, and validated autonomous operation for critical services when connectivity or orchestration planes are degraded.

g: D7 Transversal Meta-Layer.

Sovereignty: Across L1, L2, L5, and L6, the cluster reduces dependence on proprietary hardware roots of trust, non-European TEE stacks, classical cryptographic assumptions, and externally controlled network resilience mechanisms. Hardware sovereignty is primarily addressed through EU-designed secure elements and EUCC “High” assurance (L1.1), while cryptographic sovereignty is addressed through PQC migration, crypto-agility, and selected critical-link QKD (L5.2 and L5.5). **Trust and Ethics:** EUCC “High” aligns hardware assurance with Common Criteria EAL4+ and AVA_VAN.4/5 vulnerability-analysis expectations; PQC and confidential-computing migration support GDPR Article 32 confidentiality and integrity obligations [29]; the 2024 joint statement by a group of EU Member States on transition to post-quantum cryptography reinforces PQC as a collective sovereignty concern. **Sustainable Security:** Energy-efficient secure silicon and lightweight cryptography support far-edge deployment without premature device replacement, while resilient update mechanisms, crypto-agility, and validated Island Mode extend the operational lifetime of critical infrastructure assets.

B. CLUSTER 2: COGNITIVE SECURITY AND AUTONOMOUS CYBER DEFENCE

Cluster 2 consolidates the capabilities that enable cognitive security operations and autonomous cyber defence across the continuum: software and AI lifecycle assurance (CL1.2–CL1.4), federated SOC and cyber threat intelligence functions (CL2.1 and CL2.5), high-precision telemetry and AI-native analytics (CL2.2–CL2.4), deception and active defence (CL2.6), ZT reconfiguration and containment (L4.1), telecom telemetry integration (L6.1), and trustworthy algorithmic accountability for autonomous security decisions (CL4.7). The cluster is structured by three inseparable sub-dimensions: AI as a security instrument, including sovereign models, edge-native agents, autonomous SOC, and Adaptive Attack-Surface Management (AASM); AI as an adversary amplifier, including polymorphic malware, automated exploit discovery, and scaled social engineering; and AI as a target, where training pipelines and inference endpoints become attack surfaces under AI Act Article 9.

a: D1 Baseline.

At the operational cyber-resilience layer (CL2.1–CL2.6), European SOC and CTI capabilities remain fragmented across organisations, Member States, and commercial platforms, with US-platform SIEMs dominating the EU enterprise market and no EU-headquartered vendor in the Gartner Leaders quadrant [33]. At the AI lifecycle layer (CL1.2 and CL1.4), sovereign security-specific foundation models and standardised adversarial robustness validation for security AI remain underdeveloped; OpenEuroLLM [93] does not yet include a dedicated security stream. At the analytics and telemetry layer (CL2.2–CL2.4 and L6.1), NWDAF-enabled telecom telemetry and LLM-assisted SecOps are not yet operationally federated across the continuum, with current deployments concentrated at the level of individual operators and security platforms. At the governance and assurance layer (CL4.7), trustworthy, auditable, and AI Act-compliant autonomous security decision-making remains immature, particularly for systems that support containment, reconfiguration, or prioritisation of critical incidents.

b: D2 High-Impact Activities and Target Outcomes.

Activities aggregate around four target outcomes whose temporal sequencing is the subject of Section VI. The first outcome is sovereign cognitive security analytics, advanced through EU-trained security-focused small language models on EuroHPC AI Factory compute [94] and edge-deployable inference capable of operating without external cloud dependency (CL2.4). The second outcome is federated SOC and structured CTI operation, supported by MITRE ATT&CK [82], STIX/TAXII 2.1 [83], [84], and ENISA threat-landscape baselines [85], with NWDAF telemetry pipelines [81] integrated into AI-assisted triage and investigation (CL2.1, CL2.2–CL2.5, and L6.1). The third outcome is bounded autonomous response, framed as policy-constrained reconfiguration and triage rather than

open-ended automation: ZT reconfiguration aligned with NIST SP 800-207 [4] (L4.1), policy-constrained autonomous triage informed by ETSI GS ZSM 009 [95] (CL2.4), deception infrastructure as a calibration and detection mechanism (CL2.6), AASM as a research-active complement (L4.1), and adversarial-robustness validation for security AI (CL1.4) developed in alignment with AI Act Article 9 risk-management requirements [16]. The fourth outcome is trustworthy and accountable autonomous security decision-making aligned with the NIST AI RMF and Generative AI Profile [75], [76] (CL4.7).

c: D3 Primary Drivers.

The primary threat drivers for this cluster arise from the accelerating use of AI by both defenders and adversaries. At the AI lifecycle and model-assurance layer (CL1.2–CL1.4), generative AI can be weaponised for polymorphic malware, automated exploit discovery, adversarial prompt manipulation, and scaled social engineering, while training pipelines and inference endpoints become attack surfaces in their own right. At the operational cyber-resilience layer (CL2.1–CL2.6), nation-state actors increasingly blend espionage with organised crime, use memory-only execution, abuse legitimate administrative tools, and exploit fragmented SOC and CTI workflows to extend dwell time. At the analytics and telecom-telemetry layer (CL2.2–CL2.4 and L6.1), high-volume telemetry, NWDAF integration, and LLM-assisted triage create both detection opportunities and new risks of automation bias, data leakage, and adversarial manipulation. At the governance and assurance layer (CL4.7), autonomous or semi-autonomous security decisions raise accountability, auditability, and conformity-assessment challenges. The regulatory drivers are correspondingly concentrated around AI and operational resilience: AI Act Articles 9, 13, and 15 create mandatory requirements for high-risk autonomous security AI [16]; NIS2 Article 21(2)(b) establishes incident-handling obligations [14]; and conformity-assessment capacity is expected to lag obligations significantly [24].

d: D4 Catalysts and Enablers.

For AI lifecycle assurance, adversarial testing, and security-specific models (CL1.2–CL1.4), EuroHPC AI Factories provide the principal compute and training infrastructure, with cybersecurity emerging as a vertical in several sites [94]. OWASP guidance on LLM and API security complements this infrastructure by providing practical test categories for application-facing AI risks [51], [77]. For federated SOC, CTI, and operational response (CL2.1 and CL2.5), MITRE ATT&CK [82], STIX/TAXII 2.1 [83], [84], ENISA threat-landscape reporting [85], and the ECCC Strategic Agenda [92] provide the main knowledge, coordination, and governance enablers. For AI-native analytics, NWDAF integration, and autonomous triage (CL2.2–CL2.4 and L6.1), ETSI GS ZSM 009 [95], telecom analytics interfaces, and 5G/6G testbeds provide the operational automation base. For trustworthy autonomous security decisions (CL4.7), the

NIST AI RMF and Generative AI Profile [75], [76], together with AI Act conformity-assessment infrastructure, provide the principal assurance framework.

e: D5 Disruptors and Systemic Risks.

The main systemic risks affect both the AI components and the cyber-defence workflows that depend on them. For AI lifecycle assurance (CL1.2–CL1.4), hallucinations, adversarial prompt manipulation, data leakage into models, poisoned training data, and the absence of a standardised adversarial robustness test suite for security AI could undermine trust in autonomous or semi-autonomous tools. For operational cyber resilience (CL2.1–CL2.6), intelligence fragmentation, weak information-sharing incentives, and adversarial adaptation outpacing defensive innovation could prevent federated SOCs from achieving the intended dwell-time reduction. For analytics and telecom telemetry (CL2.2–CL2.4 and L6.1), high-volume data flows may increase false positives, automation bias, and dependence on opaque model outputs unless explainability and auditability are built into triage and response workflows. For trustworthy AI governance (CL4.7), conformity-assessment body capacity shortfalls [24] could delay deployment of compliant autonomous security agents even where the technical capabilities are mature.

f: D6 Failsafe Mechanisms.

Failsafe mechanisms should bound autonomy and preserve operational control when AI-assisted security systems behave unpredictably or lack sufficient assurance. For AI lifecycle capabilities (CL1.2–CL1.4), failsafes include adversarial robustness testing, red-teaming, model rollback, dataset provenance checks, and shadow-mode operation before production deployment. For operational cyber-resilience capabilities (CL2.1–CL2.6), layered detection, deception, rapid recovery playbooks, and human-in-the-loop validation for Tier-1 critical actions should prevent over-reliance on automated triage. For autonomous analytics and orchestration (CL2.4, L4.1, and L6.1), bounded autonomy governed by ETSI GS ZSM 009 [95], policy-constrained orchestration, audit logging, and shadow-mode rollback should limit unstable control loops. For ZT containment and accountable decision-making (L4.1 and CL4.7), autonomous real-time micro-segmentation should quarantine compromised components only within predefined policy boundaries, with traceable justification and escalation paths.

g: D7 Transversal Meta-Layer.

Sovereignty: Across CL1, CL2, CL4.7, L4.1, and L6.1, the cluster reduces dependence on non-European SIEM platforms, external foundation-model providers, and opaque cloud-based inference for security operations by promoting EU-sovereign security models, edge-native analytics, federated SOC coordination, and auditable autonomous response. **Trust and Ethics:** Compliance with AI Act Article 9 (risk management), Article 13 (transparency and information to deployers), Article 14 (human oversight), and Article 15

(accuracy, robustness, and cybersecurity) is central to the design and assurance of autonomous or semi-autonomous security decisions, while NIS2 sector-specific implementing acts should reference structured CTI frameworks such as MITRE ATT&CK [82] to improve operational comparability across sectors. *Sustainable Security*: Edge-native SLMs and localised analytics may reduce inference-time energy costs and latency relative to repeated cloud round-trips for high-volume telemetry workloads, subject to model-size, training-cost, and accelerator-utilisation trade-offs that are an active subject of investigation; automation can reduce analyst overload where bounded by human oversight, robust testing, and transparent governance.

C. CLUSTER 3: FEDERATED OPERATIONAL SOVEREIGNTY

Cluster 3 consolidates the capabilities that transform sovereign components into a collectively sovereign continuum: heterogeneous interoperability and Simpl integration (CL3.1), neutral-host and multi-tenant isolation (CL3.2), pan-European NaaS federation and cross-border edge roaming (CL3.3), semantic security interoperability (CL3.4), cyber range and digital twin federation (CL3.5), federated identity and access management as the jurisdiction-spanning trust primitive for federation (L4.2), dynamic supply-chain verification and Runtime SBOMs (CL1.3), continuous automated certification and assurance (CL4.2), privacy-preserving federated computation (CL4.4), and ZT policy enforcement across shared infrastructure (L4.1). Identity, supply-chain attestation, and ZT enforcement together form the federation trust fabric: identity establishes who can operate, attestation establishes what can be trusted, and ZT enforcement establishes under which conditions operation proceeds. Within this cluster, identity is treated as a jurisdiction-spanning trust primitive rather than merely an authentication convenience: traditional SSO mechanisms remain a compatibility layer, while legally recognised and cryptographically verifiable identity for users, organisations, machines, and workloads is provided by federated identity mechanisms aligned with eIDAS 2.0, the EUDI, and the W3C Verifiable Credentials Data Model [52], [53], [55]. These instruments provide a legal and technical basis for cross-border trust, while integration with cloud-edge IAM, workload identity, and NaaS federation remains operationally immature. Supply-chain verification bridges Clusters 1 and 3 because software, runtime, and federation assurance increasingly depend on the hardware roots of trust and attestation capabilities matured in Cluster 1, while federated identity provides the trust anchor required for cross-provider, cross-sector, and cross-border operation.

a: D1 Baseline.

European cloud–edge ecosystems remain fragmented across proprietary platforms, incompatible security policies, and uneven semantic models, limiting workload, policy, and assurance-evidence portability. The SIMPL-Open initial reference implementation provides an early basis for federation [67], but OASC MIM6 remains a work item, limiting

procurement-level enforceability of security-interoperability claims. Cross-provider identity still relies mainly on heterogeneous IAM stacks and bilateral trust agreements. At the identity layer (L4.2), the eIDAS 2.0 framework and the EUDI Wallet are designed primarily around natural and legal persons [53]–[55]; machine identity, workload identity, and cross-provider SSO for cloud-edge IAM depend on integration with hardware attestation (L1.1), ZT orchestration (L4.1), and federated Self-Sovereign Identity (SSI) mechanisms. CRA Software Bill of Materials (SBOM) disclosure [15], NIS2 supply-chain risk management [14], and DORA ICT third-party monitoring [17], [96] strengthen governance obligations, while CAMARA and GSMA Open Gateway expose a growing connectivity API surface [86], [97]. However, these instruments are not yet tightly coupled to runtime federation, identity-based access control, continuous assurance, or policy-coherent cross-border edge-compute roaming, while hyperscaler concentration continues to constrain effective interoperability, switching, and sovereign federation [12].

b: D2 High-Impact Activities and Target Outcomes.

Activities aggregate around four target outcomes whose temporal sequencing is the subject of Section VI. The first outcome is procurement-enforceable security interoperability through Simpl, in which OASC MIM6 progresses from work item to formally published specification, then to ratification as a CEN/CENELEC standard referenced in the EU Cloud Rulebook (CL3.1 and CL3.4). The second outcome is runtime supply-chain attestation, advanced from CRA-mandated static SBOM disclosure (CL1.3 and CL4.2) towards Runtime SBOMs supported by cryptographic proof-of-execution and zero-knowledge-proof batch verification at transaction scale. The third outcome is operational pan-European NaaS federation, deployed through harmonised CAMARA APIs across bilateral 5G corridor agreements and scaling to a federated NaaS model for cross-border edge and connectivity services (CL3.3 and L6.1), with ZT isolation enforced across shared and multi-tenant infrastructure (CL3.2 and L4.1). The fourth outcome is legally enforceable cross-jurisdictional governance of workloads, identities, and AI assets, achieved by integrating federated identity and access management with the EUDI, eIDAS 2.0 trust services, and verifiable credentials, and by enabling “Data Visa” mechanisms for dynamic AI-model and workload migration under privacy-preserving computation primitives (L4.2, CL3.1, CL4.4, and CL4.7).

c: D3 Primary Drivers.

The primary threat drivers for this cluster arise from the difficulty of federating security across heterogeneous providers, jurisdictions, identities, and supply chains. At the interoperability and federation layer (CL3.1–CL3.4 and L4.2), proprietary security policies, incompatible APIs, uneven semantic models, and identity fragmentation across Member States and across the human-machine boundary create fragmentation

that prevents European operators from scaling against US and Chinese hyperscalers and that prevents end-to-end attribution of actions across federated infrastructures. At the identity and access layer (L4.2), fragmented identity-management models, inconsistent SSO mechanisms, and weak cross-domain onboarding can undermine trust between users, organisations, machines, workloads, and providers. At the supply-chain and runtime-verification layer (CL1.3 and CL4.2), SolarWinds-class software supply-chain attacks demonstrate the risk of trusting static artefacts, opaque build pipelines, and unverifiable runtime components. At the shared-infrastructure and network-federation layer (CL3.2, CL3.3, L4.1, and L6.1), disaggregated telco clouds and cross-border edge deployments introduce multi-vendor complexity, tenant-isolation risks, and policy-enforcement gaps. The regulatory drivers are correspondingly distributed across the underlying capabilities: the Data Act strengthens portability and switching obligations [28]; eIDAS 2.0 and the EU Digital Identity Wallet framework strengthen cross-border digital identity and trust services; NIS2 requires coordinated incident response and supply-chain risk management [14]; the CRA introduces SBOM obligations [15]; DORA requires continuous ICT third-party monitoring [17]; and the DNA proposal [87] signals EC intent for network federation, although it does not mandate specific API standards.

d: D4 Catalysts and Enablers.

For heterogeneous interoperability and Simpl integration (CL3.1 and CL3.4), Digital Europe Programme funding for Simpl [67], CEN-CLC/JTC 25 data-space standardisation, the Eclipse Dataspace Protocol, and OASC/NGSI-LD semantic interoperability provide the main standardisation and implementation base. For pan-European NaaS federation and cross-border edge roaming (CL3.3 and L6.1), SNS JU activities [66], CAMARA APIs, the DNA proposal [87], and emerging aggregator models provide the principal technical and ecosystem enablers. For supply-chain verification and continuous assurance (CL1.3 and CL4.2), the IPCEI-CIS ICRA Reference Architecture [98], the EU Ecodesign Regulation Digital Product Passport, and DORA Delegated Regulation (EU) 2024/1502 for CTPP assessment [17] provide the principal policy and assurance instruments. For federated identity, SSO, and EU Digital Identity Wallet alignment (L4.2), eIDAS 2.0, the EU Digital Identity Wallet implementing framework, and interoperable identity-management profiles provide the main trust and onboarding enablers for users, organisations, machines, and workloads. For ZT isolation and shared-infrastructure governance (CL3.2 and L4.1), reusable policy profiles, certification evidence exchange, and multi-tenant isolation pilots are the key implementation enablers.

e: D5 Disruptors and Systemic Risks.

For interoperability and semantic security (CL3.1 and CL3.4), vendor resistance to open standards, proprietary API ecosystems, and uneven Member State compliance maturity could prevent convergence on common security mechanisms.

For neutral-host and multi-tenant isolation (CL3.2 and L4.1), weakest-link failures in federated systems could allow one poorly governed participant to undermine the trust assumptions of the wider federation. For identity and federation-trust (L4.2), uneven Member State rollout of the EUDI Wallet, divergent national assurance levels, and the absence of mature machine- and workload-identity profiles linked to IAM, SSI, and hardware attestation could delay end-to-end identity federation across the continuum. For supply-chain verification and continuous assurance (CL1.3 and CL4.2), limited multi-tier auditability, concentration of manufacturing and software dependencies, and SME exclusion from compliance pathways could weaken adoption. For NaaS federation and cross-border edge roaming (CL3.3 and L6.1), hyperscaler platform dominance through proprietary API ecosystems [12] could limit European scale-up. Across all federation capabilities, unresolved US CLOUD Act jurisdictional conflict [30] remains a structural sovereignty risk.

f: D6 Failsafe Mechanisms.

Failsafe mechanisms should preserve trust when federation assumptions fail or when some providers cannot meet the shared baseline. For heterogeneous interoperability and Simpl-based federation (CL3.1 and CL3.4), failsafes include autonomous unfederation, policy rollback, and fallback to minimum common security profiles. For identity-mediated federation (L4.2), failsafes include national fallback identity providers, offline-capable wallet flows, and short-lived attestation tokens that prevent prolonged authorisation outage when cross-border identity attestation is degraded. For neutral-host and multi-tenant isolation (CL3.2 and L4.1), ZT architectures should ensure that federation does not imply implicit trust [4], with cryptographic attestation of policy enforcement and graceful isolation of unverified components into quarantined network slices. For supply-chain verification and continuous assurance (CL1.3 and CL4.2), runtime attestation, trusted fallback components, and multi-vendor diversification reduce dependency on any single provider or assurance path. For NaaS federation and network resilience (CL3.3 and L6.1), graceful degradation should redirect workloads to national infrastructure, regional autonomy zones, or multi-operator fallback routing when cross-border federation is unavailable or legally constrained.

g: D7 Transversal Meta-Layer.

Sovereignty: Across CL3, CL1.3, CL4.2, L4.1, and L6.1, the cluster reduces hyperscaler lock-in by making interoperability, runtime assurance, policy portability, and cross-border edge federation enforceable rather than aspirational, while also addressing structural CLOUD Act conflict.

Trust and Ethics: Transparent and verifiable federation mechanisms support cross-border trust by making policy enforcement, runtime integrity, and assurance evidence auditable across providers and jurisdictions. The European Digital Identity Framework [53] and the EUDI Wallet [55] extend this trust posture to citizens and SMEs by giving them user-

controlled, cryptographically verifiable means of presenting attributes and credentials to federated services, while national procurement signalling such as the 2025 DINUM Bilan [99] demonstrates that sovereign-leaning procurement is operationally feasible. *Sustainable Security*: Shared federated infrastructure, reusable certification evidence, and common security profiles reduce duplication of compute, audit, and certification overhead across Member States while supporting SME access to compliant cloud-edge services.

VI. STAGE 3 OUTPUT: PHASES AND TRANSITION MATRICES

Stage 3 projects the three priority clusters identified in Section V onto the 2026–2040 roadmap horizon. It translates the capability-oriented synthesis of Stage 2 into phased cluster trajectories, showing how each cluster is expected to evolve across research and innovation maturity, policy and standardisation, operational deployment, ecosystem uptake, and strategic impact. Progression between phases is represented through transition conditions rather than deterministic forecasts. In each phase, the *Critical Enabler* identifies the principal technical, regulatory, industrial, or ecosystem condition that should be sufficiently advanced for the cluster to progress credibly toward the next maturity phase. Tables 1–3 present the resulting transition matrices. Each matrix follows the row layout introduced in Section III: two qualitative positioning rows (ODS and SovL), four assessment perspective rows, and one Critical Enabler row per phase. The matrices summarise cluster-level progression, while capability-level traceability is preserved in the corresponding Stage 2 cluster subsections, where each cluster is mapped to the layer and cross-layer capabilities defined in Section IV.

A. CLUSTER 1 TRAJECTORY: SOVEREIGN TRUSTED INFRASTRUCTURE

Phase 1 establishes the technical, software, and certification preconditions for a sovereign trusted execution substrate. Hardware roots of trust (L1.1) advance through Horizon Europe Cluster 3 consortia targeting EU-origin RISC-V secure elements for EUCC “High” pre-evaluation, with OpenTitan [43], Keystone [44], and the DARE SGA1 EuroHPC initiative [45] as principal vehicles. Secure software stack and update mechanisms (L2.1–L2.2) remain fragmented across heterogeneous edge and OT deployments, with priority given to hardening, attestation-aware middleware, and failure-resilient update paths for field-deployed nodes. Post-quantum cryptographic agility, lightweight cryptography, and confidential computing (L5.1–L5.6) remain in applied research, with FIPS 203/204/205 [57]–[59] implementations optimised for constrained microcontrollers and hybrid ML-KEM plus ECDH-P384 under ETSI TS 103 744 [62] deployed in cloud-side software, while far-edge IoT continues to operate predominantly under classical cryptography. Resilient-by-design infrastructure (L6.1–L6.4) advances through Island Mode soft-state protocols validated in 5G testbeds aligned with the SNS JU SRIA [66]. The regulatory perimeter

is binding throughout this phase, with NIS2 Article 21(2)(e) cryptographic-policy obligations [14], CRA Articles 10–11 hardware-security and lifecycle requirements [15], AI Act Articles 9 and 15 hardware-integrity obligations [16], and the NIS Cooperation Group migration milestones [13] applying concurrently. Operational TEE deployments remain dominated by Intel TDX, AMD SEV-SNP, and Arm TrustZone/CCA, and no EU-origin RISC-V processor is EUCC- or Common Criteria-certified at the start of the phase [32]. EU-headquartered designers achieved EUCC “High” for proprietary secure-element families in 2025 [31], but fabrication remains dependent on non-EU foundries and the Chips JU pilot lines [90] reach pre-production rather than commercial-source milestones.

Phase 2 industrialises the Phase 1 pipeline. The first EUCC “High” certified EU-manufactured RISC-V secure elements enter production from Chips JU pilot lines and are integrated into critical-infrastructure procurement in energy-substation and telecommunications applications across multiple Member States. Secure software stack (L2.1–L2.2) move from heterogeneous hardening practices toward standardised integration, with attestation-aware middleware, cryptographically verified update paths, staged rollout, rollback, and recovery mechanisms embedded into regulated edge deployments. RISC-V Keystone TEEs are targeted for deployment in multi-provider Data Spaces alongside Intel TDX and AMD SEV-SNP, with cross-vendor attestation interoperability ensured through the TEE abstraction layers established in Phase 1. Hybrid PQC under ETSI TS 103 744 [62] becomes the procurement default for new Industrial IoT and DORA-scoped financial-sector deployments [17], consistent with the NIS CG migration milestone for high-risk critical infrastructure [13]; lightweight PQC is demonstrated on zero-energy nodes in 6G Integrated Sensing and Communication testbeds; and autonomous Island Mode is certified under 3GPP/ETSI fallback profiles in cross-border 5G corridors. The strategic shift in this phase is procurement-side: EU-designed secure elements transition from absent in regulated-sector procurement to a credible alternative, while foreign TPMs cease to be the sole option for new regulated-sector deployments and second-source agreements between EU foundries provide production resilience.

Phase 3 consolidates the trusted execution substrate as the dominant operating pattern for new EU ICT deployments. EU-designed RISC-V secure elements are expected to become the hardware default for new security-critical EU ICT products; secure software stack and OTA update mechanisms (L2.1–L2.2) operate as continuously attested, automatically recoverable lifecycle controls; privacy-preserving computation operates end-to-end from IoT sensor to HPC compute node across federated Data Spaces; and zero-energy physical-layer authentication via RF fingerprinting (L1.2) is expected to mature as a standard identity mechanism for battery-less mMTC devices. EUCC “High” is targeted to become mandatory for new security-critical EU ICT products, PQC-native

Table 1. Cluster 1 transition matrix for Sovereign Trusted Infrastructure: phased trajectory of the trusted execution substrate across the cluster's capability set: hardware roots of trust and physical-layer assurance (L1.1–L1.2), secure software stack and OTA update mechanisms (L2.1–L2.2), cryptographic and confidential-computing mechanisms (L5.1–L5.6), and resilient network infrastructure (L6.1–L6.4).

Dimension	Phase 1 (2026–2030)	Phase 2 (2030–2035)	Phase 3 (2035–2040)
ODS	Applied R&D → Fragmented Piloting	Standardised Integration	Ubiquitous Operation
SSL	High Foreign Dependency	Emerging EU Ecosystem	Full Sovereign Autonomy
R&I Maturity	EU-origin RISC-V secure elements (OpenTitan, Keystone, DARE SGA1) target EUCC “High” pre-evaluation; FIPS 203/204/205 implementations optimised for constrained MCUs; hybrid ML-KEM + ECDH-P384 under ETSI TS 103 744 deployed cloud-side, with far-edge IoT predominantly classical; Island Mode soft-state protocols validated in 5G testbeds aligned with the SNS JU SRIA.	RISC-V Keystone TEEs deployed in multi-provider Data Spaces alongside Intel TDX and AMD SEV-SNP, with cross-vendor attestation interoperability via TEE abstraction layers; lightweight PQC demonstrated on zero-energy nodes in 6G ISAC testbeds.	Privacy-preserving computation operates end-to-end from IoT sensor to HPC compute node across federated Data Spaces; zero-energy physical-layer authentication via RFF is expected to support battery-less mMTC identity in pilot deployments.
Policy, Regulation, and Standards	NIS2 Art 21(2)(e), CRA Arts 10–11, AI Act Arts 9 and 15, and NIS CG PQC migration milestones apply concurrently; EUCC “High” framework operational.	Hybrid PQC under ETSI TS 103 744 becomes procurement default for new Industrial IoT and DORA-scoped financial-sector deployments, consistent with the NIS CG PQC milestone for high-risk critical infrastructure; autonomous Island Mode certified under 3GPP/ETSI fallback profiles in cross-border 5G corridors.	EUCC “High” is targeted to become mandatory for new security-critical EU ICT products; PQC-native silicon is targeted as the EU procurement default; continuous automated EUCC lifecycle maintenance is expected to progressively supplement point-in-time audit.
Operational Deployment and Adoption	Operational TEE deployments dominated by Intel TDX, AMD SEV-SNP, and Arm TrustZone/CCA; EUCC “High” achieved for proprietary EU secure-element families (Infineon, NXP, ST) in 2025; no EU-origin RISC-V processor EUCC- or CC-certified; Chips JU pilot lines reach pre-production rather than commercial-volume milestones.	First EUCC “High” certified EU-manufactured RISC-V secure elements enter production from Chips JU pilot lines and are integrated into critical-infrastructure procurement (energy substations, telecommunications) across multiple Member States.	EU-designed RISC-V secure elements become the hardware default for new EU ICT products; zero-energy PHY authentication operates as a standard identity mechanism in battery-less mMTC deployments.
Ecosystem Uptake and Strategic Impact	Fabrication remains dependent on non-EU foundries; sovereignty posture is defensive, defined by reducing dependency.	EU-designed secure elements transition from absent to credible alternative in regulated-sector procurement; foreign TPMs cease to be the sole option; second-source agreements between EU foundries provide production resilience.	Strategic posture transitions from defensive sovereignty, defined by reducing dependency, toward a norm-setting position, with adoption of at least one EU hardware-security standard within ISO/IEC or ITU-T as the evidence test for that transition.
Critical Enabler	EUCC “High” pre-evaluation path for an EU-origin, auditable RISC-V secure element, coupled with Chips JU pilot-line access and TEE abstraction layers to mitigate continued lock-in.	Production availability of EU-manufactured, EUCC “High” RISC-V secure elements with second-source fabrication resilience and cross-vendor attestation interoperability.	Mandatory lifecycle assurance for EUCC “High” hardware, PQC-native procurement, and international adoption of at least one EU-origin hardware-security standard.

silicon is targeted as the EU procurement default, and continuous automated EUCC lifecycle maintenance is expected to progressively supplement point-in-time audit. The strategic posture transitions from a defensive sovereignty footing, defined by reducing dependency, toward a norm-setting position in which the adoption of at least one EU hardware-security standard within ISO/IEC or ITU-T can be treated as the evidence test for that transition.

B. CLUSTER 2 TRAJECTORY: COGNITIVE SECURITY AND AUTONOMOUS CYBER DEFENCE

Phase 1 establishes the technical and assurance preconditions for cognitive cyber defence under conditions of structural dependency. Cognitive security operations advance

through commercial LLMs integrated into SOC analyst workflows for alert triage and MITRE ATT&CK technique mapping [82], NWDAF telemetry pipelines [81] routed into centralised AI analytics in 5G SA pilot deployments, and ML-based User and Entity Behaviour Analytics applied to APT IoC detection. The phase target is a credible demonstration of dwell-time reduction in at least one certified pilot in a NIS2-essential entity, measured against that entity's documented pre-pilot baseline. AI-as-target protections lag operationally: adversarial-robustness testing methodologies advance from academic research towards pilot readiness, but no operational certification framework for security-specific AI agents exists at the start of the phase, opening a regulatory gap relative to AI Act Articles 9, 13, and 15 [16], [24]. Operational

Table 2. Cluster 2 transition matrix for Cognitive Security and Autonomous Cyber Defence: phased trajectory of cognitive cyber defence across the cluster's capability set: AI lifecycle assurance and adversarial testing (CL1.2–CL1.4), federated SOC, telemetry, threat intelligence, and active defence (CL2.1–CL2.6), ZT reconfiguration and containment (L4.1), telecom telemetry integration (L6.1), and trustworthy algorithmic accountability for autonomous security decisions (CL4.7).

Dimension	Phase 1 (2026–2030)	Phase 2 (2030–2035)	Phase 3 (2035–2040)
ODS	Applied R&D → Fragmented Piloting	Standardised Integration	Ubiquitous Operation
SSL	High Foreign Dependency	Emerging EU Ecosystem	Full Sovereign Autonomy
R&I Maturity	Commercial LLMs integrated into SOC analyst workflows for alert triage and MITRE ATT&CK technique mapping; NWDAF telemetry pipelines routed into centralised AI analytics in 5G SA pilots; ML-based UEBA applied to APT IoC detection; adversarial-robustness testing methodologies advance from academic research to pilot readiness; a first EU-sovereign security-focused SLM begins training on EuroHPC AI Factory compute.	EU-sovereign SLMs trained on MITRE ATT&CK-aligned corpora deployed at the edge for real-time SOC analytics without cloud-inference dependency; Guardian nodes execute autonomous ZT reconfigurations under human-in-the-loop escalation for Tier-1 critical actions; deception infrastructure integrated into the autonomous detection loop for continuous model calibration.	Swarm-based and agentic AI techniques may be considered for continuum defence within bounded-autonomy and audit-traceable policy frameworks, with decentralised threat-intelligence sharing intended to reduce central-coordination dependency; AASM techniques, where validated, shuffle IP addressing, network topology, and software diversity within certified policy boundaries.
Policy, Regulation, and Standards	AI Act Arts 9, 13, and 15 obligations active, but no operational certification framework for security-specific AI agents at the start of the phase, opening a regulatory gap; conformity-assessment capacity expected to lag obligations.	Adversarial-robustness validation pipelines mandatory under AI Act Art 9 conformity assessment, supported by a CEN/CENELEC- or ETSI TC CYBER-published test suite for security AI; autonomous incident triage operates under ETSI GS ZSM 009 governance.	Adversarial-robustness validation is largely automated; conformity certification is treated as a precondition for operating any security AI agent in EU critical infrastructure; human oversight, consistent with AI Act Article 14, is preserved for high-risk decisions and exceptional escalations.
Operational Deployment and Adoption	US-platform LLMs serve as analyst copilots and rule-based SIEMs as primary detection infrastructure across regulated sectors; no certified autonomous containment agent in deployment; phase target is credible dwell-time reduction in at least one certified pilot in a NIS2-essential entity, measured against that entity's pre-pilot baseline.	Measurable dwell-time reductions in certified DORA-compliant, energy, and telecommunications deployments across multiple Member States; NWDAF-integrated analytics become standard in new 5G SA deployments; EuroHPC AI Factory compute contracts dedicated to EU-sovereign security-model training are activated.	Dwell-time targets converge on the threshold defined in Section VII; APT reconnaissance success rate is measurably reduced in certified Moving-Target-Defence environments.
Ecosystem Uptake and Strategic Impact	No EU-headquartered SIEM vendor in the Gartner Leaders quadrant [33]; structural dependency on US platforms; OpenEuroLLM does not yet include a dedicated security stream.	Emergence of certified EU-sovereign alternatives in regulated-sector SOC procurement, with the first export of EU AI security tools to partner jurisdictions.	AI Act-derived frameworks for trustworthy autonomous security agents referenced in bilateral digital-partnership agreements; EU AI Office and ENISA jointly contribute to the international standard for security-AI accountability.
Critical Enabler	CEN/CENELEC or ETSI TC CYBER adversarial-robustness test suite for security AI, accompanied by AI Act sandbox provisions for security use cases.	Operational AI Act conformity-assessment infrastructure for security AI (notified bodies designated under Art 9 plus a published adversarial-robustness test suite) sufficient to certify autonomous security agents for regulated-sector deployment.	Formal adoption of EU security-AI governance by at least one non-EU jurisdiction, treated as the evidence test for the leadership transition.

deployment continues to depend on US-platform LLMs as analyst copilots and on rule-based SIEMs as the primary detection infrastructure across regulated sectors, with no certified autonomous containment agent reaching deployment. The market position is one of structural dependency [33], and a first EU-sovereign security-focused small language model only begins training on EuroHPC AI Factory compute [94] during this phase.

Phase 2 operationalises sovereign cognitive defence. EU-sovereign small language models trained on MITRE ATT&CK-aligned corpora are deployed at the edge for real-time SOC analytics without cloud-inference dependency; Guardian nodes execute autonomous ZT reconfigurations consistent

with NIST SP 800-207 [4] under human-in-the-loop escalation for Tier-1 critical actions; and autonomous incident triage operates under ETSI GS ZSM 009 governance [95], with measurable dwell-time reductions in certified DORA-compliant, energy, and telecommunications deployments across multiple Member States. Adversarial-robustness validation pipelines become mandatory under AI Act Article 9 conformity assessment, supported by a CEN/CENELEC- or ETSI TC CYBER-published test suite for security AI; deception infrastructure (L6 honeynets, credential canaries, fake API endpoints) is integrated into the autonomous detection loop to provide continuous model calibration; NWDAF-integrated analytics become standard in new 5G SA deploy-

ments; and EuroHPC AI Factory compute contracts dedicated to EU-sovereign security-model training are activated. The strategic shift in this phase is the emergence of certified EU-sovereign alternatives in regulated-sector SOC procurement, and the first export of EU AI security tools to partner jurisdictions.

Phase 3 establishes bounded autonomous cyber defence as the operational baseline for regulated-sector deployments. Swarm-based and agentic AI defend the continuum within audited and certified policy frameworks, reducing central-coordination dependency without removing the audit and accountability requirements that AI Act Articles 9, 13, 14, and 15 impose; AASM shuffles IP addressing, network topology, and software diversity within certified boundaries, contributing to a measurable reduction in APT reconnaissance success in certified environments. Adversarial-robustness validation is largely automated, with conformity certification a precondition for operating any security AI agent in EU critical infrastructure, and human oversight is preserved for high-risk decisions and exceptional escalations. Dwell-time targets converge on the threshold defined in Section VII. The Phase 3 transition is evidence-tested through external adoption: AI Act-derived frameworks for trustworthy autonomous security agents are referenced in bilateral digital-partnership agreements, the EU AI Office and ENISA jointly contribute to the international standard for security-AI accountability, and the formal adoption of EU security-AI governance by at least one non-EU jurisdiction can be treated as the evidence test for the leadership transition.

C. CLUSTER 3 TRAJECTORY: FEDERATED OPERATIONAL SOVEREIGNTY

Phase 1 establishes the technical and standards preconditions for federation under conditions of regulatory fragmentation. Security interoperability advances through Simpl security MIM proof-of-concepts in Common European Data Spaces, including Manufacturing, Health [100], and Energy [67]–[69], with manual policy coordination and OASC MIM6 (Security management) progressing from work-item status towards formally published specification. Pan-European NaaS federation reaches bilateral interconnection: harmonised CAMARA Network APIs [86] are deployed in bilateral 5G corridor agreements, but cross-border edge-compute roaming does not yet exist at operational scale. Supply-chain verification remains at static disclosure under CRA Annex I Part II [15], complemented by NIS2 Article 21(2)(h) supply-chain risk assessment [14] and DORA Article 28 continuous ICT third-party monitoring [17], with the first CTPP designations operationalising the framework [96]; zero-knowledge-proof verification advances from applied research towards demonstrator readiness. The principal Phase 1 risk is regulatory fragmentation: CRA, NIS2, DORA, and the Data Act [28] activate concurrently without a unified interoperability mandate, creating compliance complexity that disproportionately burdens SMEs. The market position remains mixed: hyperscalers retain dominant share of the EU cloud

market through proprietary API ecosystems [12], supply-chain verification continues to be vendor-declared under non-EU certification ecosystems, and cross-border AI-model migration requires bespoke bilateral legal review per transfer event.

Phase 2 industrialises federation. Simpl security MIMs are ratified as CEN/CENELEC standards and referenced as mandatory compliance requirements in the EU Cloud Rulebook, transforming MIM adoption from voluntary best practice into a market-access obligation for providers serving regulated sectors. Automated policy translation is deployed across the majority of active Common European Data Spaces, federated identity attestation is automated, and cross-provider compliance reporting becomes machine-readable through OSCAL [88], [89]. Runtime SBOMs with cryptographic proof-of-execution are deployed in critical infrastructure across multiple Member States, ZKP batch verification operates at scale, and Digital Product Passports become mandatory under the EU Ecodesign Regulation for ICT hardware categories. CAMARA-based cross-border roaming operates across multiple EU operator pairs, and “Data Visa” mechanisms enable dynamic AI-model migration without manual legal review. IPCEI-CIS-aligned NaaS federation operates at pilot commercial scale [98]. The strategic shift in this phase is the first observed decline in foreign hyperscaler share of new regulated-sector cloud procurement.

Phase 3 consolidates the federated European trust fabric. Simpl-based security mechanisms become the reference pattern for cross-provider Data Space operation; ZKP-verified supply-chain attestation operates at transaction scale for critical-infrastructure component verification; and the EU NaaS federation operates with harmonised commercial and legal interfaces sufficient to support data workloads under a coordinated jurisdictional regime for procurement and assurance purposes. The defining policy instrument is an EU federated cloud-sovereignty legal framework, plausibly grounded in the Commission’s Cloud Sovereignty Framework and a future Cloud and AI Development Act [23], that would address US CLOUD Act jurisdictional conflict for federated EU-sovereign workloads [30]; the EU Cloud Rulebook would apply to new cloud deployments in regulated sectors, and EU supply-chain governance standards would be referenced in international supply-chain security standards (ISO/IEC) and in bilateral digital trade agreements. New cloud-edge deployments in regulated sectors are expected to incorporate Simpl MIM compliance, Runtime SBOM verification, and cross-border sovereignty assurance from inception. Full federated sovereign autonomy is conditional on three concurrent outcomes: foreign hyperscaler new-procurement share below the threshold defined in Section VII, enactment of an EU federated cloud-sovereignty legal framework, and at least two partner jurisdictions formally adopting EU supply-chain governance standards.

Table 3. Cluster 3 transition matrix for Federated Operational Sovereignty: phased trajectory of the European trust fabric across the cluster’s capability set: dynamic supply-chain verification and Runtime SBOMs (CL1.3), security interoperability, federation, semantic alignment, and cyber-range validation (CL3.1–CL3.5), continuous automated certification and assurance (CL4.2), privacy-preserving federated computation (CL4.4), and ZT policy enforcement across shared infrastructure (L4.1).

Dimension	Phase 1 (2026–2030)	Phase 2 (2030–2035)	Phase 3 (2035–2040)
ODS	Applied R&D → Fragmented Piloting (heterogeneous across sub-capabilities)	Standardised Integration	Ubiquitous Operation
SSL	High Foreign Dependency for cloud platforms and SBOM verification; Emerging EU Ecosystem for Simpl, CAMARA APIs, and DORA CTPP oversight	Emerging EU Ecosystem	Full Sovereign Autonomy
R&I Maturity	Simpl security MIM proof-of-concepts in Common European Data Spaces (Manufacturing, Health, Energy) under manual policy coordination; OASC MIM6 (Security management) progresses from work-item status towards formally published specification; ZKP verification advances from applied research towards demonstrator readiness.	Runtime SBOMs with cryptographic proof-of-execution deployed in critical infrastructure across multiple Member States; ZKP batch verification operates at scale; “Data Visa” mechanisms enable dynamic AI-model migration across European jurisdictions without manual legal review.	ZKP-verified supply-chain attestation operates at real-time transaction scale for all critical-infrastructure component verification; Simpl-based security becomes the universal standard for cross-provider Data Space operation.
Policy, Regulation, and Standards	CRA Annex I Part II static SBOM disclosure, NIS2 Art 21(2)(h) supply-chain risk assessment, DORA Art 28 continuous ICT third-party monitoring (first CTPP designations, November 2025), and Data Act portability obligations activate concurrently without a unified interoperability mandate; principal risk is regulatory fragmentation that disproportionately burdens SMEs.	Simpl security MIMs ratified as CEN/CENELEC standards and referenced as mandatory compliance requirements in the EU Cloud Rulebook; cross-provider compliance reporting machine-readable through OSCAL; Digital Product Passports mandatory under the EU Ecodesign Regulation for ICT hardware categories.	An EU federated cloud-sovereignty legal framework, plausibly grounded in the Commission’s Cloud Sovereignty Framework and a future Cloud and AI Development Act [23], would be required to address US CLOUD Act jurisdictional conflict for federated EU-sovereign workloads; the EU Cloud Rulebook would need to apply to new cloud deployments in regulated sectors; EU supply-chain governance standards (Runtime SBOM and ZKP) would need to be referenced in international supply-chain security standards and in bilateral digital trade agreements.
Operational Deployment and Adoption	Harmonised CAMARA Network APIs [97] are deployed in bilateral 5G corridor agreements; cross-border edge-compute roaming is not yet operational at scale; supply-chain verification remains at static disclosure stage; cross-border AI-model migration requires bespoke bilateral legal review per transfer event.	Automated policy translation across the majority of active Common European Data Spaces; federated identity attestation automated; CAMARA-based cross-border roaming operates across multiple EU operator pairs; IPCEI-CIS-aligned NaaS federation at pilot commercial scale [98].	The EU NaaS federation operates with harmonised commercial and legal interfaces sufficient to support data workloads under a coordinated jurisdictional regime for procurement and assurance purposes; new cloud-edge deployments in regulated sectors are expected to incorporate SimplMIM compliance, Runtime SBOM verification, and cross-border sovereignty assurance from inception; Runtime SBOM attestation operates as a continuous-evidence pipeline aligned with the EUCC and (when adopted) ECCC for Cloud Services catalogues.
Ecosystem Uptake and Strategic Impact	Hyperscalers retain dominant share of the EU cloud market through proprietary API ecosystems; EU-headquartered providers collectively at a structurally lower share; supply-chain verification vendor-declared under non-EU certification ecosystems [12].	First observed decline in foreign hyperscaler share of new regulated-sector cloud procurement; MIM compliance becomes a market-access obligation for providers serving regulated sectors.	Foreign hyperscaler new-procurement share below the threshold defined in Section VII; at least two partner jurisdictions formally adopt EU supply-chain governance standards.
Critical Enabler	Simpl-Open MVP consolidation with formal publication of OASC MIM6 (Security management).	Ratification of Simpl MIMs as CEN/CENELEC standards with mandatory reference in the EU Cloud Rulebook, coupled with operational Runtime SBOM attestation in critical infrastructure across multiple Member States.	Enactment of an EU federated cloud-sovereignty legal framework resolving CLOUD Act conflict, with international adoption of EU supply-chain governance standards.

VII. STRATEGIC RECOMMENDATIONS

The 2040 destination is a secure, sovereign, interoperable, and resilient European Cloud–Edge–IoT continuum. The

seven recommendations below derive directly from the cluster trajectories of Section VI. Each recommendation names

the action, the cluster or cross-cutting dependency it addresses, the Phase 1 gate it conditions, the quantified Phase 2 and Phase 3 targets it carries, and the principal risk to delivery. Recommendations R1–R3 are cluster-aligned; recommendations R4–R7 address dependencies shared by two or more clusters and require dedicated cross-cluster governance to avoid becoming systemic bottlenecks.

A. CLUSTER-ALIGNED RECOMMENDATIONS

a: R1: Sovereign Secure Silicon and Crypto-Agile Infrastructure (Cluster 1).

Combine Horizon Europe Cluster 3 funding with EU Chips Act pilot lines to advance EU-origin open-source RISC-V secure elements (L1.1) towards EUCC “High” assurance, while delivering crypto-agility middleware aligned with the NIS CG PQC roadmap [13] and ETSI TS 103 744 hybrid key-exchange profiles [62] (L5.2). Existing EUCC “High” certifications achieved by major EU secure-element vendors [31] demonstrate framework readiness; the remaining gap is open-source, EU-controlled fabrication and operationalised PQC migration for edge and IoT. The medium-term target is to establish EU-designed secure elements as a credible option in new critical-infrastructure procurement, make hybrid PQC the default for new regulated-sector deployments, and validate autonomous Island Mode in cross-border network environments. The long-term target is broad EUCC “High” coverage across critical-infrastructure edge nodes, PQC-native silicon as the procurement default, and autonomous Island Mode as a baseline resilience property for essential and critical deployments. Principal risk: EU Chips Act fabrication-capacity shortfall (R4).

b: R2: Sovereign Cognitive Cyber Defence with Bounded Autonomy (Cluster 2).

Build on EuroHPC AI Factories [94] and the ECCC Strategic Agenda [92] to deliver EU-sovereign security-focused small language models (CL1.2 and CL2.4), federated SOC and structured CTI operation (CL2.1, CL2.5), bounded autonomous response under ETSI GS ZSM 009 [95] and NIST SP 800-207 [4] (CL2.4 and L4.1), and trustworthy autonomous decision-making aligned with the NIST AI RMF [75], [76] and AI Act Article 9 conformity assessment [16] (CL4.7). The near-term target is to demonstrate measurable dwell-time reduction in certified pilots for regulated or essential entities, using documented pre-pilot baselines. The medium-term target is to deploy EU-sovereign security models and AI-assisted SOC analytics across regulated-sector environments, with human-in-the-loop escalation for critical actions and adversarial-robustness validation as part of conformity assessment. The long-term target is bounded, auditable, and policy-constrained autonomous cyber defence in critical infrastructure, including certified AASM and accountable agentic-security workflows. Principal risk: AI Act conformity-assessment capacity shortfall (R5).

c: R3: Procurement-Enforceable Federation through Simpl, Runtime SBOMs, and Continuous Certification (Cluster 3).

Move OASC MIM6 (Security management) from work-item status to formally published specification, then to ratified CEN/CENELEC standard referenced in the EU Cloud Rulebook (CL3.1 and CL3.4), so that interoperability carries procurement-level enforcement. In parallel, advance supply-chain verification from CRA-mandated static SBOM disclosure [15] to Runtime SBOMs with cryptographic proof-of-execution and zero-knowledge-proof batch verification (CL1.3 and CL4.2), and use EUCC [19] as the assurance foundation while unblocking ECCC for Cloud Services [18] to extend continuous assurance to cloud services. Federate SOC and CTI capabilities across Member States by building on DORA CTPP oversight [96] and cross-border CSIRT cooperation [80]. The medium-term target is to make Simpl MIM compliance, Runtime SBOM attestation, machine-readable assurance evidence, and CAMARA-based cross-border roaming credible operational options for regulated-sector deployments. The long-term target is a federated European trust fabric in which supply-chain attestation, policy portability, cross-border NaaS federation, and continuous assurance are incorporated into new regulated cloud-edge deployments from inception. Principal risk: Runtime SBOM attestation maturity (R6).

B. CROSS-CUTTING RECOMMENDATIONS

a: R4: EU Chips Act Sovereign Fabrication for Security-Critical Components (Clusters 1 and 3).

EU Chips Act and Chips JU pilot-line investments strengthen Europe’s semiconductor capacity [90], but dedicated fabrication pathways for security-critical components, including secure elements and attestation-capable hardware, remain insufficiently developed. Recent audit findings highlight the risk that EU semiconductor capacity may fall short of strategic autonomy objectives [91], while continued dependence on major non-EU foundries could impair critical-infrastructure attestation capability during geopolitical or supply-chain disruption. Action: establish dedicated pilot-line access for security-critical components, secure second-source agreements between EU foundries, and implement strategic stockpiling of EUCC-certified secure elements for critical-infrastructure procurement. This recommendation conditions the early transition gate of R1 and the Runtime SBOM hardware-attestation path of R6.

b: R5: AI Act Conformity Assessment Infrastructure for Security AI (Cluster 2).

A material gap between AI Act obligations and conformity-assessment body operational readiness has been documented [24], while sandbox pathways for security-specific AI use cases remain insufficiently operationalised. Action: accelerate CEN/CENELEC and ETSI TC CYBER development of an adversarial-robustness test suite for security AI, designate competent conformity-assessment capacity for security-AI systems under AI Act Article 9, and operationalise AI Act

sandbox pathways for cyber-defence use cases. This recommendation conditions the early transition gate of R2; without credible test suites, notified-body capacity, and sandbox validation, autonomous security agents cannot be certified for regulated-sector deployment regardless of technical readiness.

c: R6: Runtime SBOM Attestation Beyond CRA Static Disclosure (Clusters 1 and 3).

Static SBOMs mandated by CRA Annex I Part II [15] are insufficient for dynamic continuum operations in which containerised microservices and AI components migrate across providers and jurisdictions. Action: progress from static SBOM disclosure to Runtime SBOMs, cryptographic proof-of-execution mechanisms, and zero-knowledge-proof batch verification anchored in hardware roots of trust matured under R1 and aligned with the IPCEI-CIS ICRA Reference Architecture [98]. The medium-term target is to make runtime supply-chain attestation operationally usable in regulated cloud-edge environments. The long-term target is continuous, machine-readable supply-chain evidence that can support cross-provider federation, automated assurance, and procurement-level trust decisions. This recommendation is the principal mechanism by which Cluster 1 hardware attestation is operationalised for Cluster 3 federation.

d: R7: SME Inclusion across Sovereign Hardware, Cognitive Defence, and Federation (all clusters).

Cost and compliance barriers could prevent SMEs from adopting sovereign hardware alternatives, AI-assisted SOC tooling, and Simpl MIM-compliant federation services, turning NIS2, CRA, and AI Act implementation into a barrier to participation in the European digital industrial base. Action: implement tiered certification pathways under EUCC and ECCC for Cloud Services, subsidise shared cyber-range and digital-twin access (CL3.5), provide reusable compliance tooling based on machine-readable control catalogues [88], [89], and target Digital Europe Programme co-funding at shared-infrastructure pathways for SME access to secure elements, EU-sovereign security models, and federation services. This recommendation conditions the ecosystem-uptake dimension of all three cluster trajectories: without SME-accessible deployment and assurance pathways, sovereign capabilities risk remaining concentrated among large industrial actors and public bodies.

VIII. DISCUSSION, LIMITATIONS, AND FUTURE WORK

The roadmap is an evolving strategic artefact rather than a deterministic forecast. Its value lies in providing a shared analytical structure through which stakeholders can align research, policy, deployment, and investment decisions around a common set of objectives, and in making cross-cluster dependencies and phase-gate conditions explicit enough to support portfolio-level decision-making under conditions of ecosystem uncertainty. The roadmap has benefited from expert input and remains intended to support stakeholder dis-

cussion and iterative refinement as technical, regulatory, and market conditions evolve.

Three limitations bound the analysis. First, the Cloud–Edge–IoT landscape is shaped by rapidly evolving technologies, regulatory implementation, market dynamics, and geopolitical conditions, all of which may alter cluster trajectories; the roadmap should be read as a strategic synthesis of the state of the art and expert judgement rather than a precise prediction. Second, the *Sovereignty Level* construct is used as an interpretive lens rather than a quantitative score, and its operational comparability across clusters depends on identifying measurable proxies for strategic dependency. Third, the targets and recommendations in Section VII are anchored in the current evidence base and require revision as enforcement, certification, and procurement signals evolve.

Future work should extend this analysis in three directions. First, the architectural analysis should be instantiated in sector-specific use cases, including energy, healthcare, finance, and public procurement, to examine how regulation, procurement rules, supply-chain constraints, and market structure modify the generic cluster trajectories. Second, the *Sovereignty Level* construct should be further operationalised through measurable proxies, such as provider concentration, certification availability, fabrication capacity, and cross-border deployability, enabling more systematic cross-cluster comparison. Third, the roadmap should remain an iterative instrument, periodically revised as empirical evidence, stakeholder feedback, regulatory milestones, technological developments, and funding priorities evolve, including through reassessment of early transition conditions as enforcement, certification, and procurement signals progress.

IX. CONCLUSION

The Cloud–Edge–IoT continuum requires Europe to move beyond reactive and fragmented cybersecurity models towards autonomous, federated, and certified Security-by-Design. The three-stage methodology presented here decomposes the continuum into Security Layers and Transversal Security Cross-Layers, consolidates the resulting capabilities into three priority clusters, and projects each cluster onto a 2026–2040 transition matrix in which a single Critical Enabler per phase functions as the gate condition for progression. The seven recommendations translate the ambition–implementation gap into actionable priorities across trusted infrastructure, cognitive cyber defence, and federated operational sovereignty. The principal transition risks differ across clusters: Cluster 1 depends on secure-element fabrication capacity, Cluster 2 on adversarial-robustness standardisation and conformity-assessment infrastructure for security AI, and Cluster 3 on moving federation mechanisms from voluntary specification to procurement-enforceable reference. Addressing these bottlenecks is essential for European cybersecurity policy, industrial capability, and digital sovereignty objectives to converge into deployable and resilient cloud-edge infrastructure.

ACKNOWLEDGEMENTS

This sections is left intentionally blank to preserve the integrity of the blind review process.

References

- [1] S. Dustdar, V. C. Pujol, and P. K. Donta, "On distributed computing continuum systems," vol. 35, pp. 4092–4105. [Online]. Available: <https://ieeexplore.ieee.org/document/9681207/>
- [2] L. Bittencourt, R. Immich, R. Sakellariou, N. Fonseca, E. Madeira, M. Curado, L. Villas, L. DaSilva, C. Lee, and O. Rana, "The Internet of Things, Fog and Cloud continuum: Integration and challenges," vol. 3-4, pp. 134–155. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S2542660518300635>
- [3] European Alliance for Industrial Data, Edge and Cloud. European Industrial Technology Roadmap for the Next-Generation Cloud-Edge. [Online]. Available: <https://digital-strategy.ec.europa.eu/en/policies/cloud-alliance>
- [4] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, "Zero Trust Architecture." [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf>
- [5] R. Chandramouli and Z. Butcher, "A zero trust architecture model for access control in cloud-native applications in multi-location environments." [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207A.pdf>
- [6] A. Alwarafy, K. A. Al-Thelaya, M. Abdallah, J. Schneider, and M. Hamdi, "A survey on security and privacy issues in edge-computing-assisted Internet of Things," vol. 8, pp. 4004–4022. [Online]. Available: <https://ieeexplore.ieee.org/document/9163078/>
- [7] R. Roman, J. Lopez, and M. Mambo, "Mobile edge computing, Fog et al.: A survey and analysis of security threats and challenges," vol. 78, pp. 680–698. [Online]. Available: <https://linkinghub.elsevier.com/retrieve/pii/S0167739X16305635>
- [8] P. Ranaweera, A. D. Jurcut, and M. Liyanage, "Survey on multi-access edge computing security and privacy," vol. 23, pp. 1078–1124. [Online]. Available: <https://ieeexplore.ieee.org/document/9364272/>
- [9] R. Chandramouli, "Implementation of DevSecOps for a microservices-based application with service mesh." [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-204C.pdf>
- [10] ENISA, "Good Practices for Security of IoT – Secure Software Development Lifecycle." [Online]. Available: <https://www.enisa.europa.eu/publications/good-practices-for-security-of-iot-1>
- [11] A. Cavoukian and Others, "Privacy by design: The 7 foundational principles," vol. 5, p. 12.
- [12] Synergy Research Group. European Cloud Infrastructure Market Share. [Online]. Available: <https://www.srgresearch.com/articles/european-cloud-providers-local-market-share-now-holds-steady-at-15>
- [13] NIS Cooperation Group. A Coordinated Implementation Roadmap for the Transition to Post-Quantum Cryptography. [Online]. Available: <https://digital-strategy.ec.europa.eu/en/library/coordinated-implementation-roadmap-transition-post-quantum-cryptography>
- [14] European Parliament and Council. Directive (EU) 2022/2555 on measures for a high common level of cybersecurity across the Union (NIS 2 Directive). [Online]. Available: <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32022L2555>
- [15] —. Regulation (EU) 2024/2847 on horizontal cybersecurity requirements for products with digital elements (Cyber Resilience Act). [Online]. Available: <https://eur-lex.europa.eu/eli/reg/2024/2847/oj/eng>
- [16] —. Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (AI Act). [Online]. Available: <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng>
- [17] —. Regulation (EU) 2022/2554 on digital operational resilience for the financial sector (DORA). [Online]. Available: <https://eur-lex.europa.eu/eli/reg/2022/2554/oj/eng>
- [18] —. Regulation (EU) 2019/881 on information and communications technology cybersecurity certification (Cybersecurity Act). [Online]. Available: <https://eur-lex.europa.eu/eli/reg/2019/881/oj/eng>
- [19] European Commission. European common criteria-based cybersecurity certification scheme (EUCC). [Online]. Available: https://eur-lex.europa.eu/legal-content/EN/LSU/?uri=OJ:L_202400482
- [20] "Digital Sovereignty for Europe." [Online]. Available: https://www.europarl.europa.eu/RegData/etudes/BRIE/2020/651992/EPRS_BRI%282020%29651992_EN.pdf
- [21] H. Carrapico and B. Farrand, "Cybersecurity trends in the European union: Regulatory mercantilism and the digitalisation of geopolitics," vol. 62, pp. 147–158. [Online]. Available: <https://onlinelibrary.wiley.com/doi/abs/10.1111/jcms.13654>
- [22] European Commission. NIS2 Directive transposition in EU countries. [Online]. Available: <https://digital-strategy.ec.europa.eu/en/policies/nis-2-transposition>
- [23] —. Cloud Sovereignty Framework. [Online]. Available: https://commission.europa.eu/document/download/09579818-64a6-4dd5-9577-446ab6219113_en?filename=Cloud-Sovereignty-Framework.pdf
- [24] European Parliament Think Tank. Enforcement of the AI Act. [Online]. Available: https://www.europarl.europa.eu/RegData/etudes/ATAG/2026/785670/EPRS_ATA%282026%29785670_EN.pdf
- [25] ETSI, "Multi-access Edge Computing (MEC); Framework and Reference Architecture." [Online]. Available: http://rfc.nop.hu/etsi2/gs_MEC003v040101p.pdf
- [26] Trusted Computing Group, "Trusted Platform Module (TPM) 2.0 Library." [Online]. Available: <https://trustedcomputinggroup.org/resource/tpm-library-specification/>
- [27] R. Sailer, X. Zhang, T. Jaeger, and L. van Doorn, "Design and Implementation of a TCG-based Integrity Measurement Architecture," in *13th USENIX Security Symposium (USENIX Security 04)*. USENIX Association. [Online]. Available: <https://www.usenix.org/conference/13th-usenix-security-symposium/design-and-implementation-tcg-based-integrity-measurement>
- [28] European Parliament and Council. Regulation (EU) 2023/2854 on harmonised rules on fair access to and use of data (Data Act). [Online]. Available: <https://eur-lex.europa.eu/eli/reg/2023/2854/oj/eng>
- [29] —. Regulation (EU) 2016/679 on the protection of natural persons with regard to the processing of personal data (GDPR). [Online]. Available: <https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng>
- [30] P. Kunert. Microsoft admits it cannot guarantee data sovereignty. [Online]. Available: https://www.theregister.com/2025/07/25/microsoft_admits_it_cannot_guarantee/
- [31] ENISA. EUCC – European Cybersecurity Certification Scheme. [Online]. Available: https://certification.enisa.europa.eu/browse-topic/eucc_en
- [32] A. Muñoz, R. Ríos, R. Román, and J. López, "A survey on the (in)security of trusted execution environments," vol. 129, p. 103180. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S0167404823000901>
- [33] Gartner. Gartner Magic Quadrant for Security Information and Event Management. [Online]. Available: <https://www.gartner.com/en/documents/7040298>
- [34] Department for Science, Innovation and Technology. UK Compute Roadmap. [Online]. Available: https://assets.publishing.service.gov.uk/media/6878b5dda52cca025ef5bd87/uk_compute_roadmap_web_accessible.pdf
- [35] Semiconductor Research Corporation and Semiconductor Industry Association, "The Decadal Plan for Semiconductors." [Online]. Available: <https://www.src.org/about/decadal-plan/>
- [36] World Economic Forum and AI Governance Alliance, "Blueprint to Action: China's Path to AI-Powered Industry Transformation." [Online]. Available: https://reports.weforum.org/docs/WEF_Blueprint_to_Action_Chinas_Path_to_AI-Powered_Industry_Transformation_2025.pdf
- [37] G. Li, Ed., *Information Science & Technology in China: A Roadmap to 2050*. Springer Berlin Heidelberg. [Online]. Available: <https://link.springer.com/book/10.1007/978-3-642-19071-1>
- [38] European Cyber Security Organisation. ECSO's Strategic Vision: European Cybersecurity 2030. [Online]. Available: <https://ecs-org.eu/?publications=ecsos-strategic-vision-european-cybersecurity-2030>
- [39] R. Phaal, C. J. P. Farrukh, and D. R. Probert, "Technology roadmaping—A planning framework for evolution and revolution," vol. 71, pp. 5–26. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S0040162503000726>
- [40] National Institute of Standards and Technology, "The NIST Cybersecurity Framework (CSF) 2.0." [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>
- [41] ISO/IEC, "ISO/IEC 27400:2022: Cybersecurity — IoT security and privacy — Guidelines." [Online]. Available: <https://www.iso.org/standard/44373.html>
- [42] ENISA, "Baseline Security Recommendations for IoT in the Context of Critical Information Infrastructures." [Online]. Available: <https://www.enisa.europa.eu/publications/baseline-security-recommendations-for-iot>

- [43] lowRISC. OpenTitan: Open source silicon root of trust (RoT). [Online]. Available: <https://opentitan.org>
- [44] D. Lee, D. Kohlbrenner, S. Shinde, K. Asanović, and D. Song, "Keystone: an open framework for architecting trusted execution environments," in *Proceedings of the Fifteenth European Conference on Computer Systems*. ACM, pp. 1–16. [Online]. Available: <https://dl.acm.org/doi/10.1145/3342195.3387532>
- [45] EuroHPC JU. DARE SGA1: Digital Autonomy for RISC-V in Europe (Specific Grant Agreement 1). [Online]. Available: <https://cordis.europa.eu/project/id/101202459>
- [46] M. Harizaj, A. Kara, and I. Symeonidis, "The dual challenges for radio Frequency Fingerprinting trustworthiness: Feature drift modeling and the privacy imperative for deployable Physical Layer Security," vol. 15, p. 1309. [Online]. Available: <https://www.mdpi.com/2079-9292/15/6/1309>
- [47] B. Moran, H. Tschofenig, D. Brown, and M. Meriac, "A Firmware Update Architecture for Internet of Things." [Online]. Available: <http://dx.doi.org/10.17487/RFC9019>
- [48] Uptane Alliance Community, "IEEE-ISTO 6100.1.2.0 – Uptane Standard for Design and Implementation." [Online]. Available: <https://uptane.org/papers/ieee-isto-6100.1.0.0.uptane-standard.pdf>
- [49] R. Chandramouli, "Security strategies for microservices-based application systems." [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-204.pdf>
- [50] R. Chandramouli and Z. Butcher, "Building secure microservices-based applications using service-mesh architecture." [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-204A.pdf>
- [51] OWASP Foundation. OWASP API Security Top 10. [Online]. Available: <https://owasp.org/API-Security/>
- [52] W3C Verifiable Credentials Working Group, "Verifiable Credentials Data Model v2.0." [Online]. Available: <https://www.w3.org/TR/vc-data-model-2.0/>
- [53] European Parliament and Council. Regulation (EU) 2024/1183 establishing the European Digital Identity Framework. [Online]. Available: <https://eur-lex.europa.eu/eli/reg/2024/1183/oj/eng>
- [54] European Commission. Commission Implementing Regulation (EU) 2024/2979 integrity and core functionalities of European Digital Identity Wallets. [Online]. Available: https://eur-lex.europa.eu/legal-content/EN/TXT/PDF/?uri=OJ:L_202402979
- [55] European Parliament and of the Council. Regulation (EU) 2024/1183 establishing the European Digital Identity Framework. [Online]. Available: <https://eur-lex.europa.eu/eli/reg/2024/1183/oj/eng>
- [56] Confidential Computing Consortium. A Technical Analysis of Confidential Computing, v1.3. [Online]. Available: https://confidentialcomputing.io/wp-content/uploads/sites/10/2023/03/CCC-A-Technical-Analysis-of-Confidential-Computing-v1.3_unlocked.pdf
- [57] Module-Lattice-Based Key-Encapsulation Mechanism Standard (ML-KEM). [Online]. Available: <https://csrc.nist.gov/pubs/fips/203/final>
- [58] Module-Lattice-Based Digital Signature Standard (ML-DSA). [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.204.pdf>
- [59] Stateless Hash-Based Digital Signature Standard (SLH-DSA). [Online]. Available: <https://csrc.nist.gov/pubs/fips/205/final>
- [60] ETSI, "Quantum Key Distribution (QKD); Protocol and Data Format of REST-based Key Delivery API." [Online]. Available: https://www.etsi.org/deliver/etsi_gs/QKD/001_099/014/01.01.01_60/gs_qkd014v010101p.pdf
- [61] —, "Quantum Key Distribution (QKD); Application Interface." [Online]. Available: https://www.etsi.org/deliver/etsi_gs/QKD/001_099/004/02.01.01_60/gs_qkd004v020101p.pdf
- [62] —, "CYBER; Quantum-safe hybrid key exchanges." [Online]. Available: https://www.etsi.org/deliver/etsi_ts/103700_103799/103744/01.02.01_60/ts_103744v010201p.pdf
- [63] 3GPP, "Security Architecture and Procedures for 5G System." [Online]. Available: https://www.etsi.org/deliver/etsi_ts/133500_133599/133501/18.09.00_60/ts_133501v180900p.pdf
- [64] O-RAN Alliance. O-RAN Security Requirements and Controls Specifications 8.0. [Online]. Available: <https://www.o-ran.org/specifications>
- [65] —, "Zero Trust Architecture for Secure O-RAN – WG11 Security White Paper." [Online]. Available: <https://mediastorage.o-ran.org/white-papers/O-RAN.WG11.ZTA%20for%20Secure%20O-RAN%20White%20Paper-2024-05.pdf>
- [66] Smart Networks and Services Joint Undertaking, "Strategic Research and Innovation Agenda (SRIA)." [Online]. Available: <https://www.cbe.europa.eu/strategic-research-and-innovation-agenda-sria>
- [67] European Commission. Simpl: Cloud-to-edge federations empowering EU data spaces. [Online]. Available: <https://digital-strategy.ec.europa.eu/en/policies/simpl>
- [68] Open & Agile Smart Cities (OASC). MIMs - Open & Agile Smart Cities & Communities. [Online]. Available: <https://oascities.org/minimal-inter-operability-mechanisms/>
- [69] ETSI, "Context Information Management (CIM); NGSI-LD API." [Online]. Available: https://www.etsi.org/deliver/etsi_gs/CIM/001_099/09/01.08.01_60/gs_cim009v010801p.pdf
- [70] L. T. A. N. Brandão, N. Mouha, and A. Vassilev, "Threshold schemes for cryptographic primitives: challenges and opportunities in standardization and validation of threshold cryptography." [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/ir/2019/NIST.IR.8214.pdf>
- [71] ISO/IEC, "ISO/IEC 18033-6:2019: IT Security techniques — Encryption algorithms Part 6: Homomorphic encryption." [Online]. Available: <https://www.iso.org/standard/67740.html>
- [72] Martin Albrecht, Melissa Chase, Hao Chen, Jintai Ding, Shafi Goldwasser, Sergey Gorbunov, Shai Halevi, Jeffrey Hoffstein, Kim Laine, Kristin Lauter, Satya Lokam, Daniele Micciancio, Dustin Moody, Travis Morrison, Amit Sahai, Vinod Vaikuntanathan, "Homomorphic Encryption Security Standard." [Online]. Available: <https://homomorphicencryption.org/standard/>
- [73] 3GPP, "Study on security aspects of 3GPP support for Non-Terrestrial Networks (NTN)." [Online]. Available: <https://itecspec.com/3gpp/archiv/e/33.836>
- [74] F. Rinaldi, H.-L. Maattanen, J. Torsner, S. Pizzi, S. Andreev, A. Iera, Y. Koucheryavy, and G. Araniti, "Non-terrestrial networks in 5G & beyond: A survey," vol. 8, pp. 165 178–165 200. [Online]. Available: <https://ieeexplore.ieee.org/document/9193893/>
- [75] E. Tabassi, "Artificial intelligence risk management Framework (AI RMF 1.0)." [Online]. Available: <http://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf>
- [76] NIST, "AI Risk Management Framework: Generative AI Profile." [Online]. Available: <https://digitalgovernmenthub.org/examples/nist-artificial-intelligence-risk-management-framework-generative-artificial-intelligence-profile/>
- [77] OWASP Foundation. OWASP Top 10 for Large Language Model Applications. [Online]. Available: <https://owasp.org/www-project-top-10-for-large-language-model-applications>
- [78] OpenSSF. Supply-chain Levels for Software Artifacts. [Online]. Available: <https://slsa.dev/>
- [79] A. Madry, A. Makelov, L. Schmidt, D. Tsipras, and A. Vladu, "Towards deep learning models resistant to adversarial attacks." [Online]. Available: <http://dx.doi.org/10.48550/arXiv.1706.06083>
- [80] G. Dreo, C. Schmitt, and A. van der Wees, "Deliverable D4.4: Cybersecurity Roadmap for Europe." [Online]. Available: https://www.concordia-h2020.eu/wp-content/uploads/2021/03/Deliverables_D4.4-M24.pdf
- [81] 3GPP, "Architecture Enhancements for 5G System to Support Network Data Analytics Services." [Online]. Available: <https://itecspec.com/3gpp/archive/23.288>
- [82] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington, and C. B. Thomas, "MITRE ATT&CK: Design and Philosophy." [Online]. Available: <https://www.mitre.org/sites/default/files/2021-11/prs-19-01075-28-mitre-attack-design-and-philosophy.pdf>
- [83] OASIS OPEN. STIX Version 2.1. [Online]. Available: <https://docs.oasis-open.org/cti/stix/v2.1/os/stix-v2.1-os.html>
- [84] B. Jordan and D. Varner. TAXII Version 2.1. [Online]. Available: <https://docs.oasis-open.org/cti/taxii/v2.1/os/taxii-v2.1-os.html>
- [85] ENISA, "ENISA Threat Landscape 2025." [Online]. Available: <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>
- [86] CAMARA. Fall25 meta-release. [Online]. Available: <https://if-camaraproject.atlassian.net/wiki/spaces/CAM/pages/36241429/Fall25+meta-release>
- [87] (2026, Jan.) Digital Networks Act (DNA). European Commission. [Online]. Available: <https://digital-strategy.ec.europa.eu/en/policies/digital-networks-act>
- [88] Open Security Controls Assessment Language (OSCAL). [Online]. Available: <https://pages.nist.gov/OSCAL/>
- [89] M. Iorga and D. Waltermire, "OSCAL: The Open Security Controls Assessment Language – Project Overview." [Online]. Available: <https://csrc.nist.gov/Projects/open-security-controls-assessment-language>
- [90] European Parliament and Council. Regulation (EU) 2023/1781 establishing a framework of measures for strengthening Europe's

- semiconductor ecosystem (European Chips Act). [Online]. Available: <https://eur-lex.europa.eu/legal-content/EN/LSU/?uri=CELEX:32023R1781>
- [91] European Court of Auditors. Special Report 12/2025: The European Chips Act. [Online]. Available: <https://www.eca.europa.eu/en/publications?ref=SR-2025-12>
- [92] European Cybersecurity Competence Centre. ECCC Strategic Agenda. [Online]. Available: https://cybersecurity-centre.europa.eu/strategic-agenda_en
- [93] OpenEuroLLM Consortium. OpenEuroLLM. [Online]. Available: <https://www.openeurollm.eu/>
- [94] EuroHPC JU. AI Factories. [Online]. Available: https://www.eurohpc-ju.europa.eu/ai-factories_en
- [95] ETSI, “Zero-touch network and Service Management (ZSM); Closed-Loop Automation.” [Online]. Available: https://www.etsi.org/deliver/etsi_gs/ZSM/001_099/00901/01.01.01_60/gs_ZSM00901v010101p.pdf
- [96] European Supervisory Authorities. Designation of Critical ICT Third-Party Providers under DORA. [Online]. Available: <https://www.eba.europa.eu/publications-and-media/press-releases/european-supervisory-authorities-designate-critical-ict-third-party-providers-under-digital>
- [97] GSMA. GSMA Open Gateway. [Online]. Available: <https://www.gsma.com/solutions-and-impact/gsma-open-gateway/>
- [98] European Commission. Important Project of Common European Interest on Next Generation Cloud Infrastructure and Services (IPCEI-CIS). [Online]. Available: https://competition-policy.ec.europa.eu/state-aid/ipcei/approved-ipceis/cloud_en
- [99] La direction interministérielle du numérique (DINUM). Bilan 2025 du cloud public. [Online]. Available: <https://www.numerique.gouv.fr/sinformer/espace-presse/etat-transition-cloud-offres-europeennes-souveraines/>
- [100] European Parliament and Council. Regulation (EU) 2025/327 on the European Health Data Space (EHDS). [Online]. Available: <https://eur-lex.europa.eu/eli/reg/2025/327/oj/eng>

APPENDIX. CAPABILITY CATALOGUE AND REFERENCES

• • •

Table 4. Layer and cross-layer capabilities with their principal references.

Code	Capability	Primary references
L1.1	Hardware Roots of Trust; EU open-hardware (RISC-V) to EUCC “High”	[26], [27], [43]–[45]
L1.2	Physical-layer threat detection and RF fingerprinting	[6], [8], [46]
L2.1	OS and middleware hardening; sovereign edge Linux	[4], [9]
L2.2	Secure OTA patch and update management	[47], [48]
L3.1	Workload security (service mesh, mTLS, sidecar)	[49], [50]
L3.2	In-band network telemetry and deep observability	[49], [50]
L3.3	API security gateway and policy enforcement	[9], [51]
L4.1	Zero Trust orchestration (PEP/PDP)	[4], [5]
L4.2	Federated IAM and SSI; eIDAS 2.0 and EUDI Wallet	[52]–[55]
L4.3	Privileged Access Management (PAM) and JIT	[4], [5]
L5.1	Confidential computing and TEEs	[44], [56]
L5.2	Post-Quantum Cryptography (PQC) for edge/IoT	[13], [57]–[59], [62]
L5.3	Signalling/data-plane cryptographic authentication	[63]–[66]
L5.4	Distributed reputation and trust networking (DLT)	[18], [67]–[69]
L5.5	Quantum Key Distribution (QKD) for critical links	[60], [61]
L5.6	Privacy-preserving computation: SMPC and homomorphic encryption	[16], [29], [70]–[72]
L6.1	Telco-cloud and O-RAN security	[63]–[66]
L6.2	Physical resilience and IT/OT safety	[6], [8], [63], [66]
L6.3	Edge-native autonomous guardians	[64]–[66]
L6.4	Non-terrestrial network and satellite security	[73], [74]
CL1.1	Continuous DevSecOps	[9]
CL1.2	Model integrity and DataBOMs	[75]–[77]
CL1.3	Dynamic supply-chain verification; Runtime SBOMs	[78]
CL1.4	Automated adversarial testing and purple teaming	[51], [77], [79]
CL2.1	Automated SOC and collaborative CTI	[80]
CL2.2	High-precision telemetry and security signalling	[81], [85]
CL2.3	Internet of Behaviour and evidence sharing	[82]–[85]
CL2.4	AI-native analytics (NWDFAF, LLM-SecOps)	[75]–[77], [81]
CL2.5	CTI lifecycle management	[82]–[85]
CL2.6	Deception technology and active defence	[82], [85]
CL3.1	Simpl integration and heterogeneous interoperability	[67]–[69]
CL3.2	Neutral host and multi-tenant isolation	[4], [5]
CL3.3	Pan-European NaaS federation	[86], [87]
CL3.4	Semantic security interoperability	[68], [69]
CL3.5	Cyber range and digital twin federation	[3], [18], [80]
CL4.1	Post-Quantum Cryptography (PQC) readiness and Zero Trust architectures	[4], [5], [57]–[59]
CL4.2	Continuous automated certification (EUCC; EUCS)	[18], [19], [88], [89]
CL4.3	Multicloud Key Management as a Service	[4], [5], [57]–[59]
CL4.4	Cross-Jurisdictional Federated AI Governance	[28], [29], [56]
CL4.6	Cyber risk quantification and board-level reporting	[14], [17], [40]
CL4.7	AI trustworthiness and algorithmic accountability	[16], [75], [76]